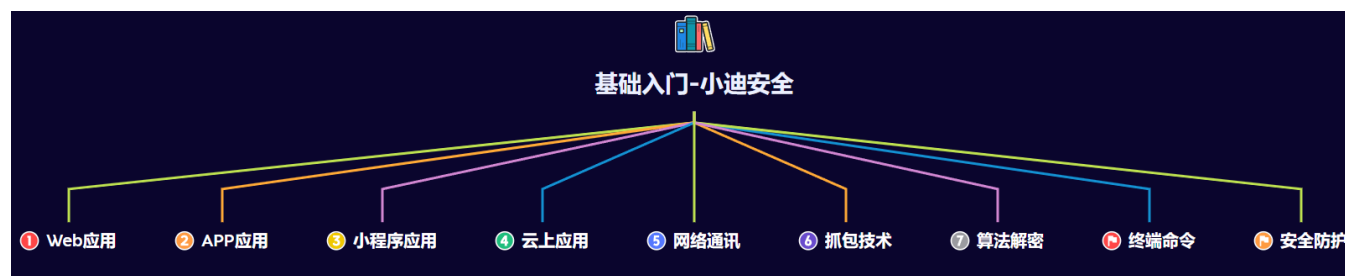


Day06 基础入门-抓包技术&HTTPS协议&APP&小程序&PC应用&Web&证书信任&转发联动



1.知识点

- 1、基础入门-Web应用-域名上的技术要点
- 2、基础入门-Web应用-源码上的技术要点
- 3、基础入门-Web应用-数据上的技术要点
- 4、基础入门-Web应用-解析上的技术要点

- 1、基础入门-Web应用-搭建架构上的技术要点
- 2、基础入门-Web应用-源码类别上的技术要点

- 1、基础入门-Web应用-防护产品-WAF保护
- 2、基础入门-Web应用-加速服务-CDN节点
- 3、基础入门-Web应用-文件托管-OSS存储
- 4、基础入门-Web应用-通讯服务-反向代理
- 5、基础入门-Web应用-运维安全-负载均衡

- 1、基础入门-Web应用-蜜罐系统
- 2、基础入门-Web应用-堡垒机运维
- 3、基础入门-Web应用-内外API接口
- 4、基础入门-Web应用-第三方拓展架构

- 1、基础入门-APP应用-开发架构安全问题
- 2、基础入门-小程序应用-开发架构安全问题

- 1、抓包技术-Web应用-http/s-Burp&Yakit
- 2、抓包技术-APP应用-http/s-Burp&Yakit

- 3、抓包技术-PC端应用-http/s-Burp&Yakit
- 4、抓包技术-WX小程序-http/s-Burp&Yakit
- 5、抓包技术-软件联动-http/s-Proxifier
- 6、抓包技术-通用方案-http/s-ReqableApi
- 7、抓包技术-其他工具-http/s-Fiddler&Charles

2.详细点

- 架构：WEB,APP,小程序,前后端,容器化等
- 服务：OSS存储,CDN加速,云数据库,负载均衡等
- 网络：不回显,反向代理,防火墙出入站,内外网,正反向连接等
- 算法：MD5,Base64,AES,DES,Salt,自定义,代码加密算法等
- 命令：Windows&Linux,文件下载,网络查看,反弹权限,用户等
- 防护：WAF防护,蜜罐系统,CDN加速,权限设置,加壳加密反调试等

3.演示案例



- 1 准备工作：
- 2 1、浏览器安装证书：解决本地抓HTTPS
- 3 2、模拟器安装证书：解决模拟器抓HTTPS
- 4 3、真机器安装证书：解决真机器抓HTTPS
- 5 注：本地装证书一定要装在受信任和中间两个选项里面



- 1 Fiddler:
- 2 <https://www.telerik.com/fiddler>
- 3 是一个http协议调试代理工具，它能够记录并检查所有你的电脑和互联网之间的http通讯，设置断点，查看所有的“进出”Fiddler的数据（指cookie,html,js,css等文件）。Fiddler 要比其他的网络调试器要更加简单，因为它不仅仅暴露http通讯还提供了一个用户友好的格式。



- 1 Charles:
- 2 <https://www.charlesproxy.com/>
- 3 是一个HTTP代理服务器,HTTP监视器,反转代理服务器，当浏览器连接Charles的代理访问互联网时，Charles可以监控浏览器发送和接收的所有数据。它允许一个开发者查看所有连接互联网的HTTP通信，这些包括request, response和HTTP headers （包含cookies与caching信息）。



- 1 BurpSuite:
- 2 是用于攻击web 应用程序的集成平台，包含了许多工具。Burp Suite为这些工具设计了许多接口，以加快攻击应用程序的过程。所有工具都共享一个请求，并能处理对应的HTTP 消息、持久性、认证、代理、日志、警报。



- 1 Reqable:
- 2 <https://reqable.com/>
- 3 是一款跨平台的专业 HTTP 开发和调试工具，在全平台支持 HTTP1、HTTP2 和 HTTP3(QUIC)协议，简单易用、功能强大、性能高效，助力程序开发和测试人员提高生产力！说白了，他就是抓包工具 + Postman的合体，既可以抓包，又可以测试接口。



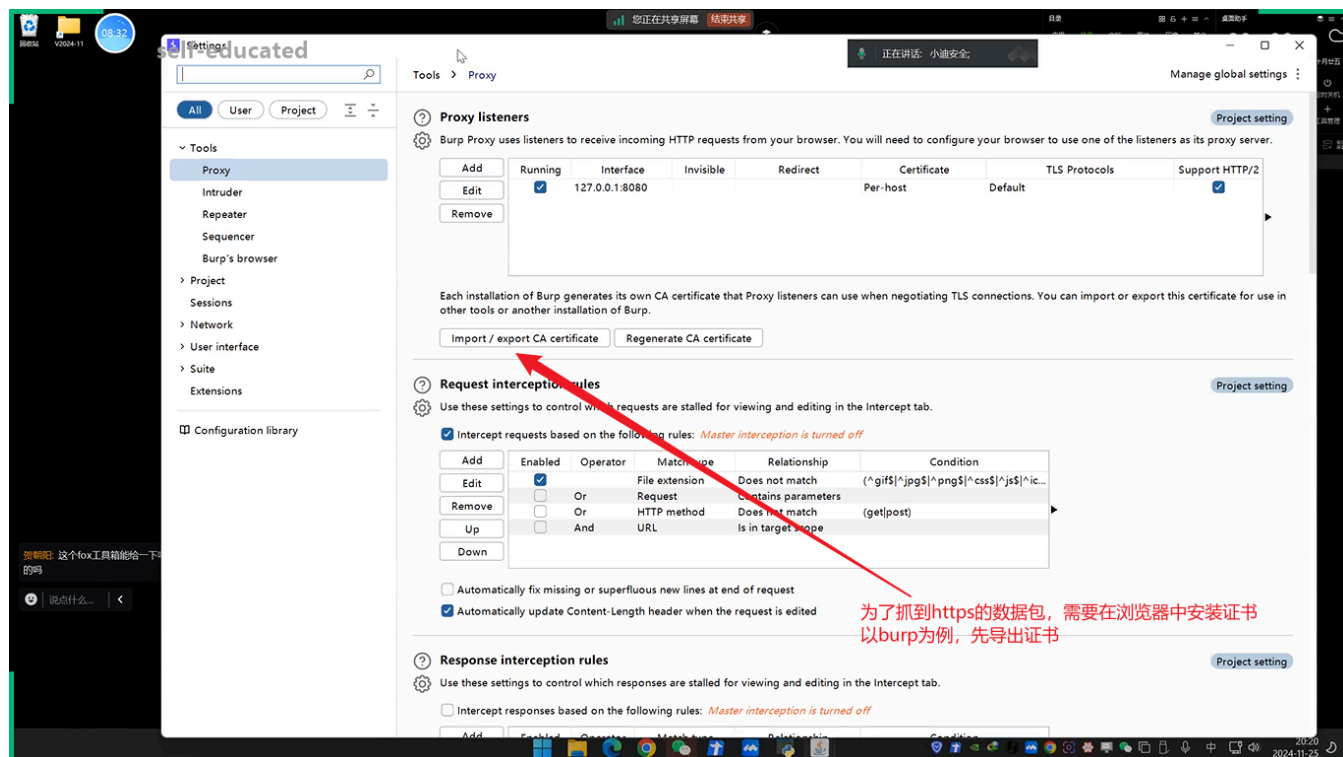
- 1 Yakit:
- 2 <https://www.yaklang.com>
- 3 Yakit 是一个基于 Yak 语言的安全领域垂直语言工具，它提供了一个图形化用户界面（GUI）来操控 Yak 引擎的能力。Yakit 旨在降低使用安全工具的门槛，使得安全从业者即使没有编程技能也能轻松地进行安全测试和分析。

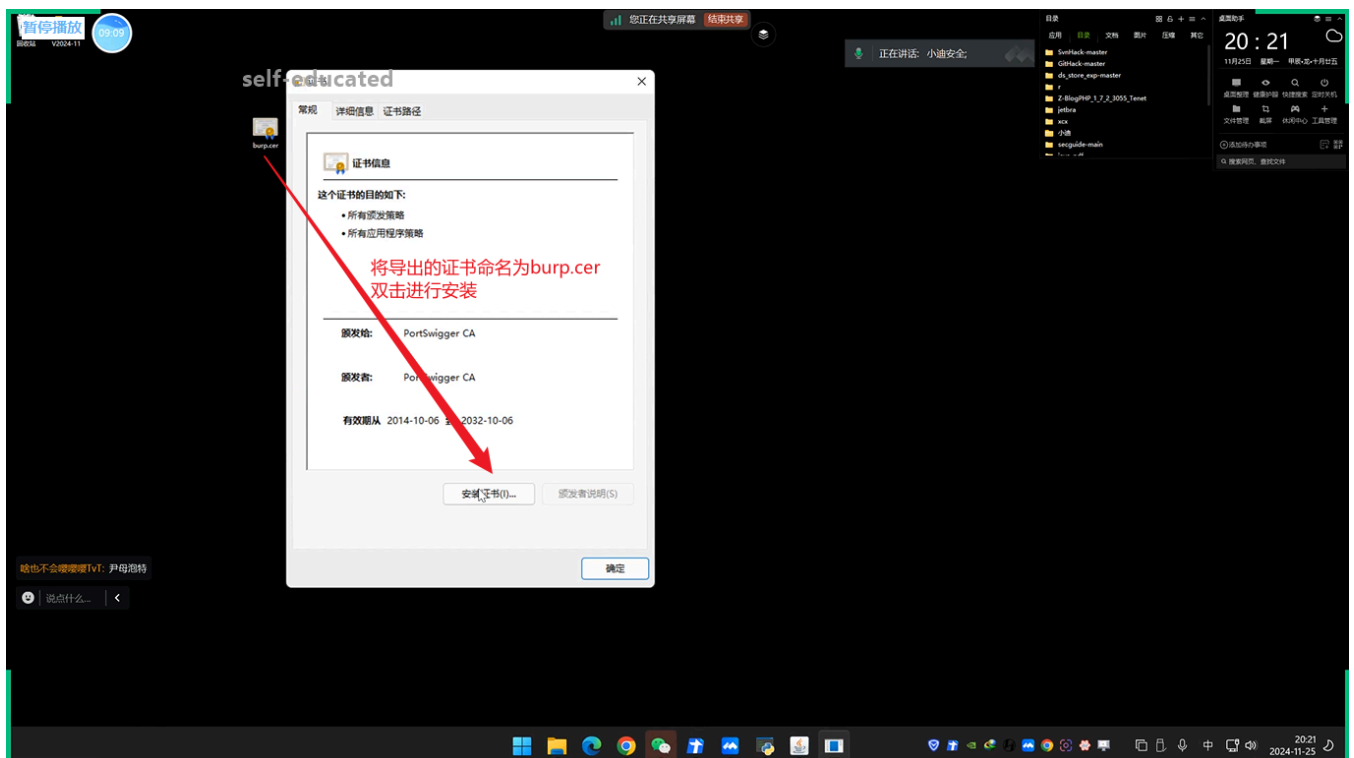
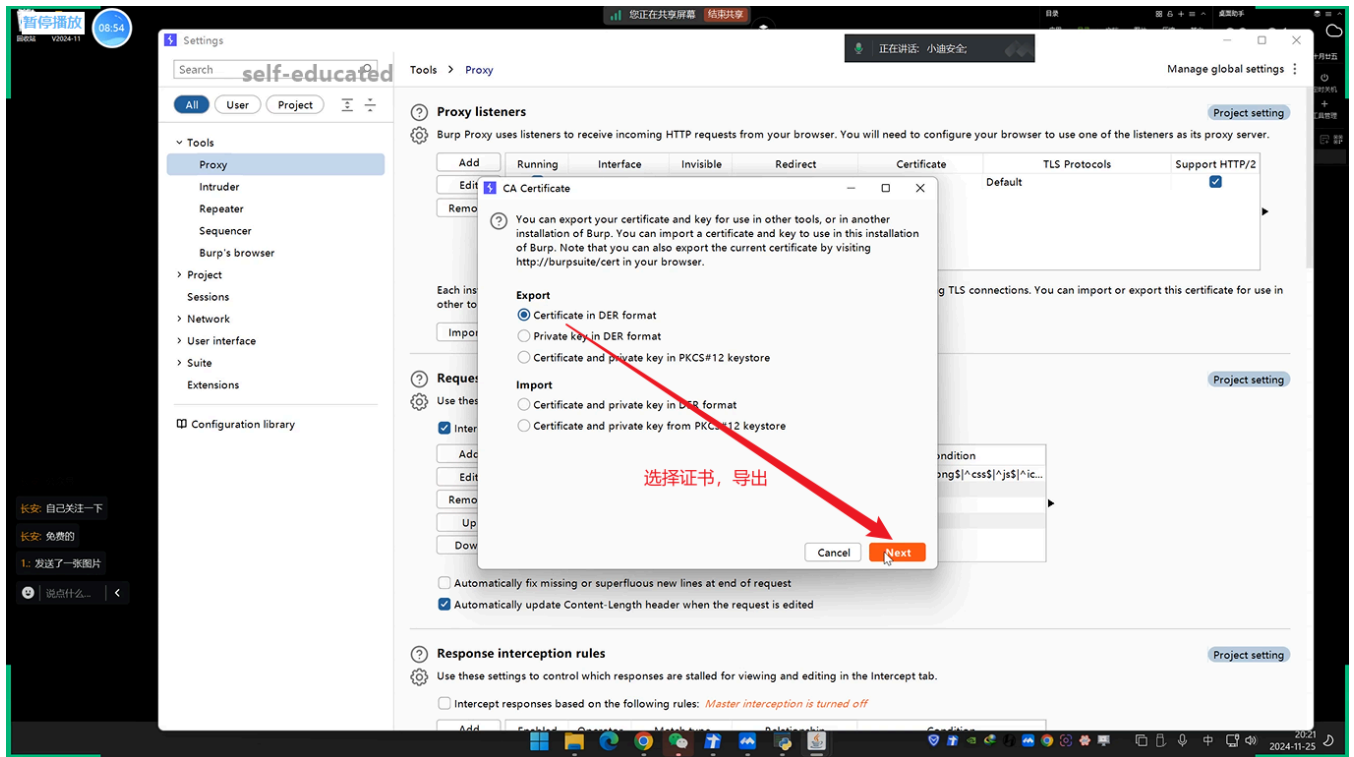


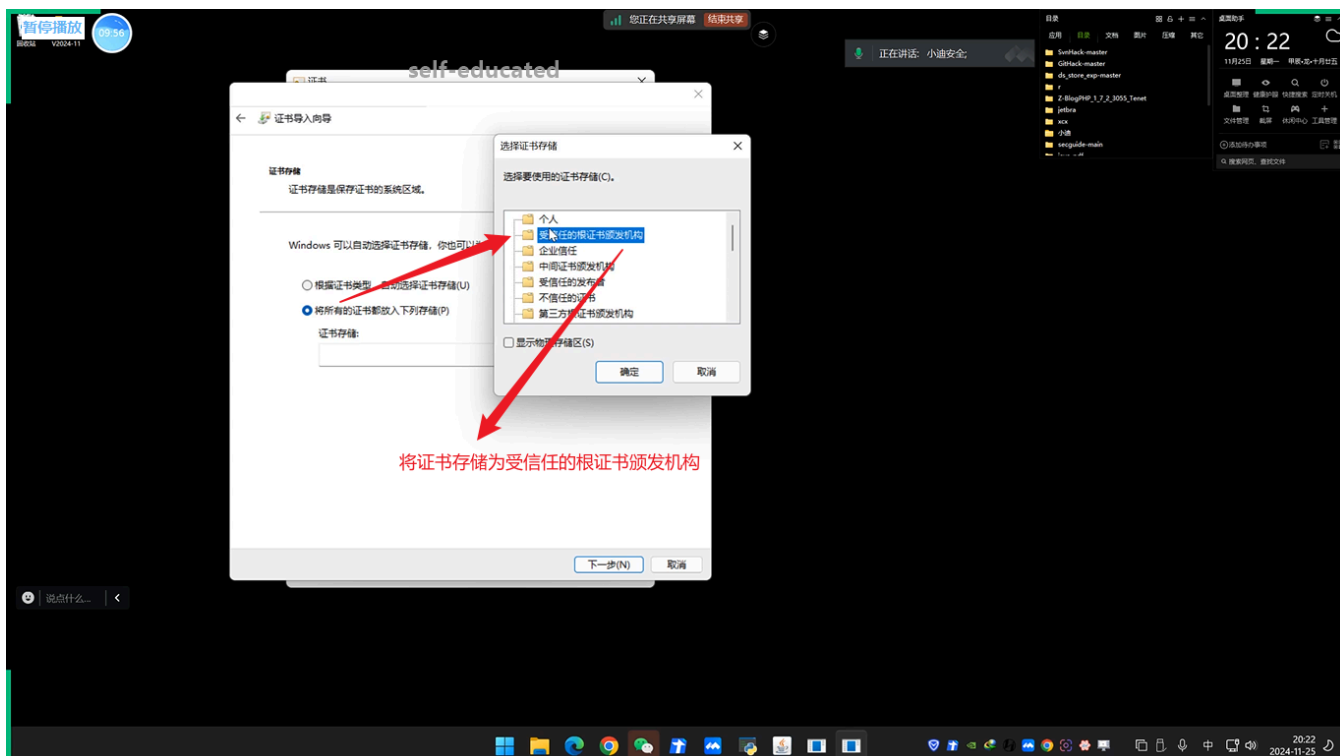
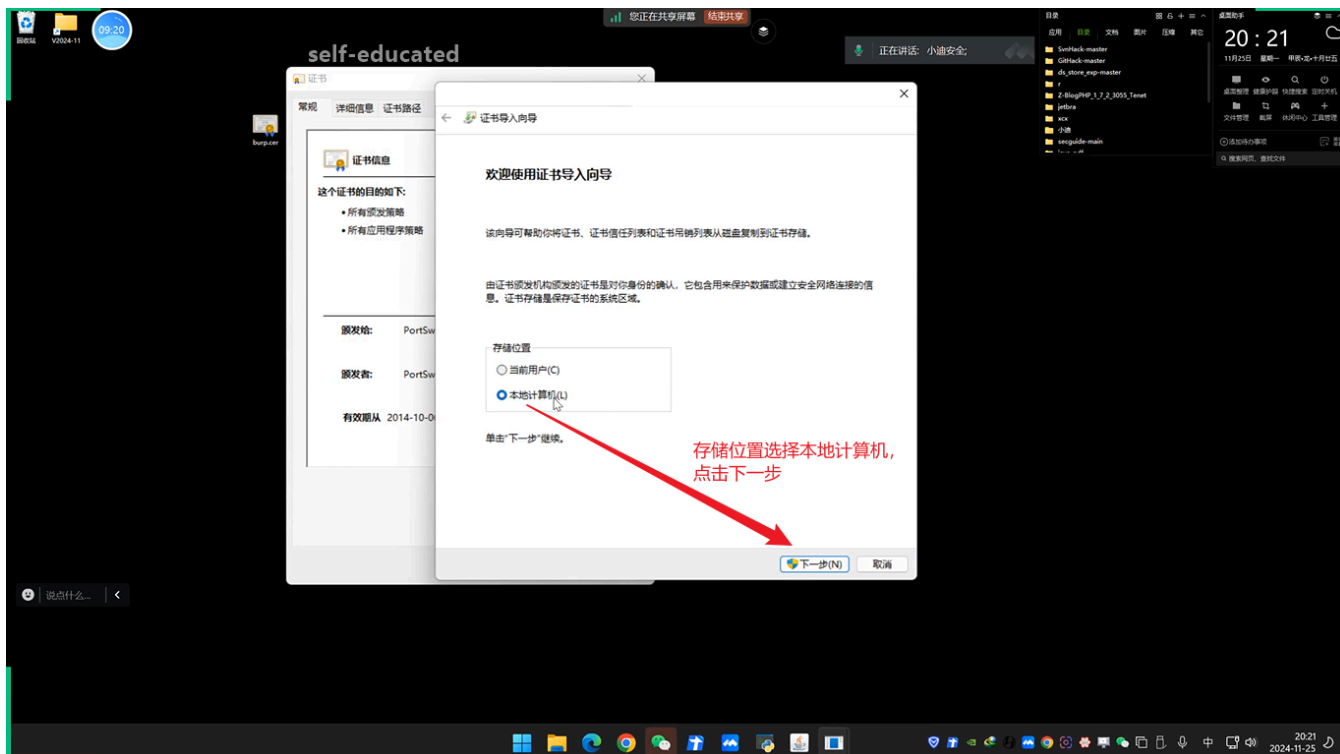
- 1 Proxifier:
- 2 一款功能强大的网络代理工具，它可以让你将网络应用程序通过代理服务器进行连接。它提供了一个简单而灵活的方式，让你能够将任何应用程序的网络流量路由到指定的代理服务器上，从而实现匿名浏览、绕过网络封锁、访问受限网站等功能。

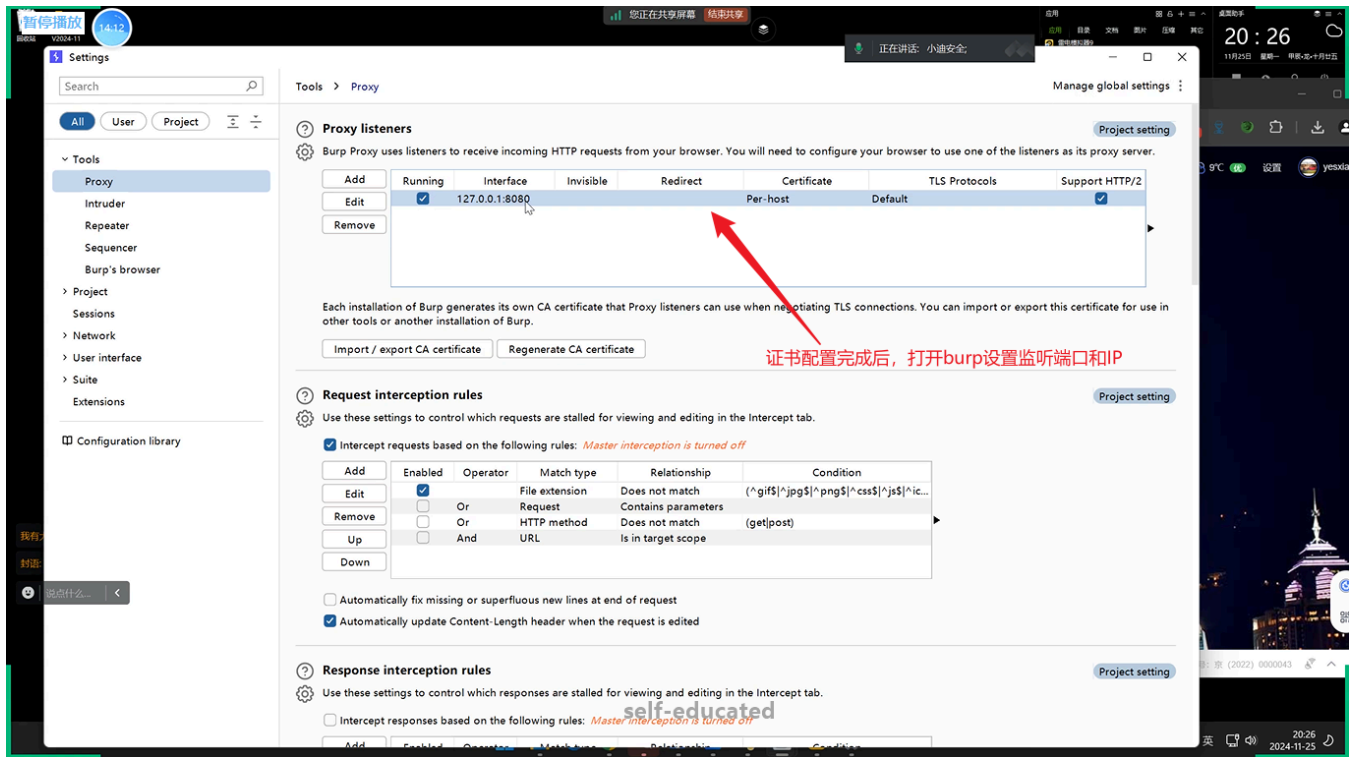
3.1 抓包技术-Web&App&小程序&PC-Burp&Yakit

3.1.1 Web-Burp

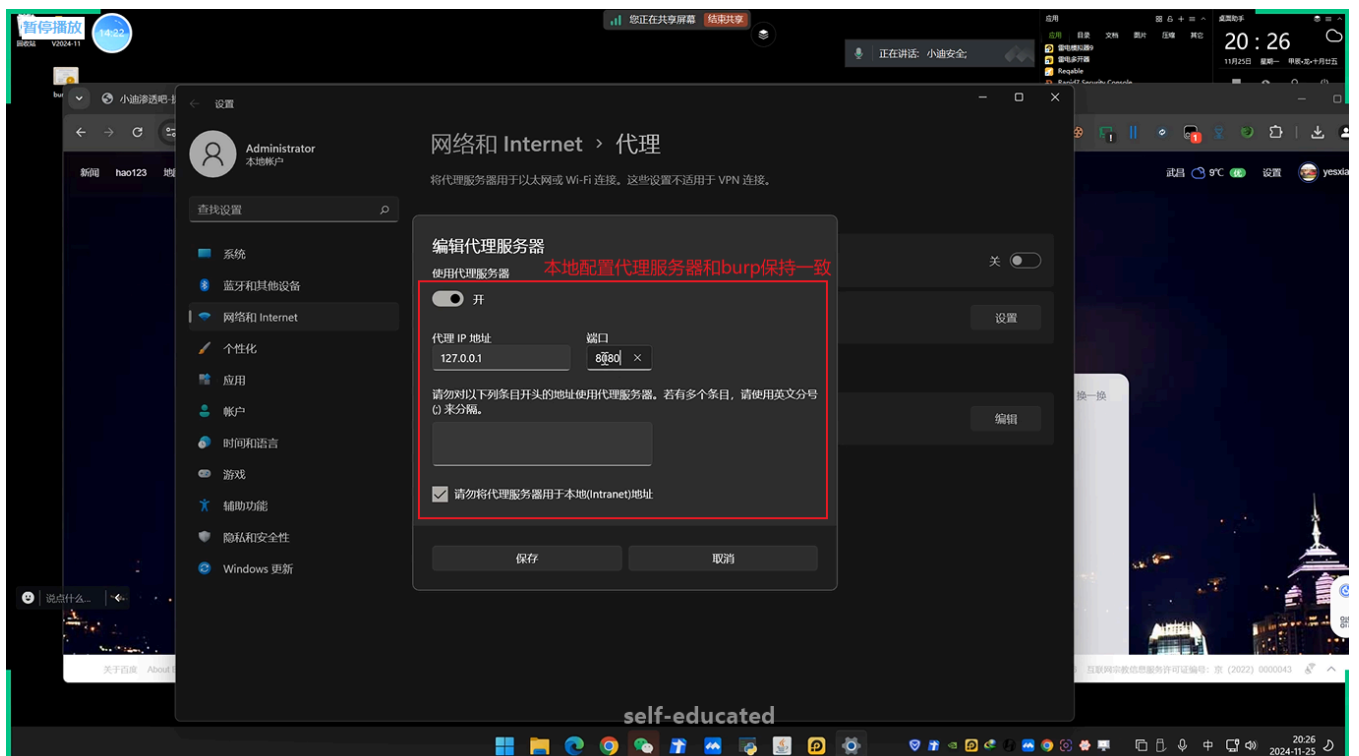


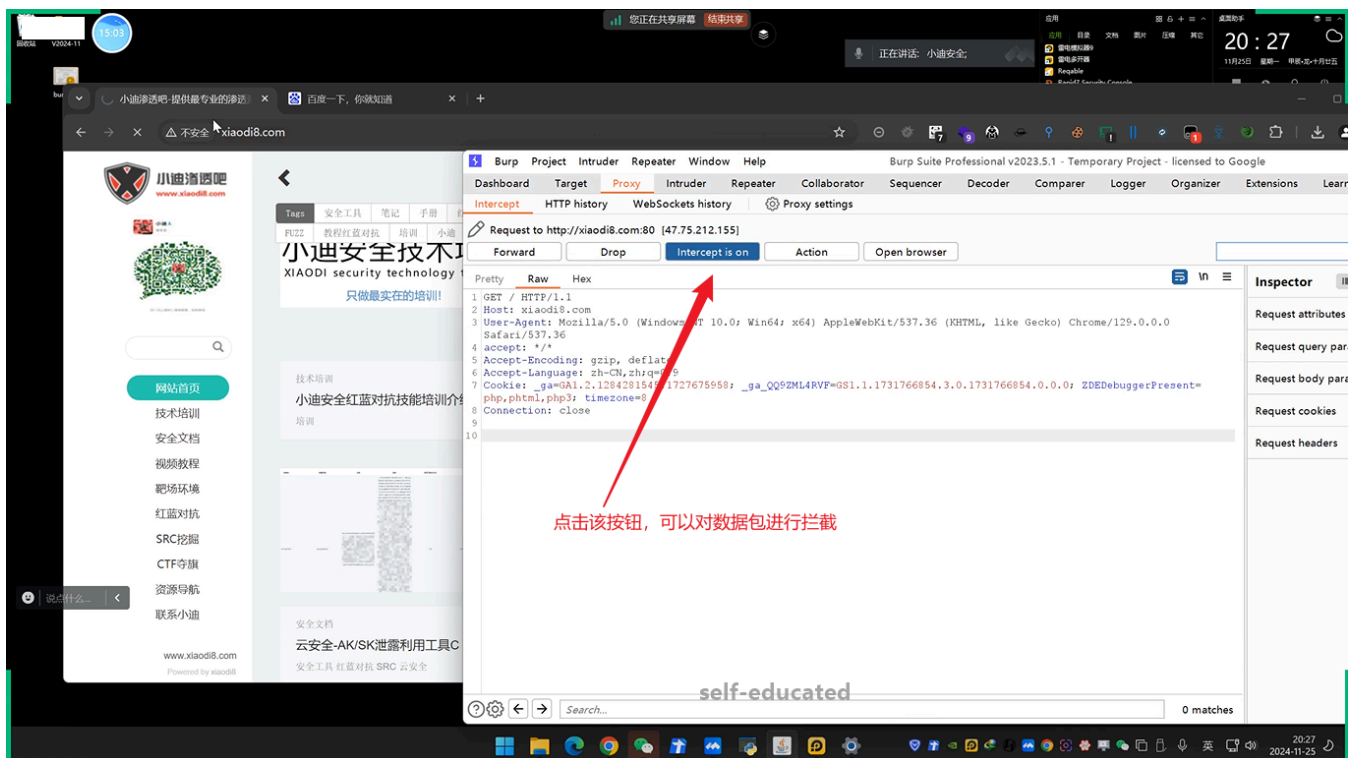
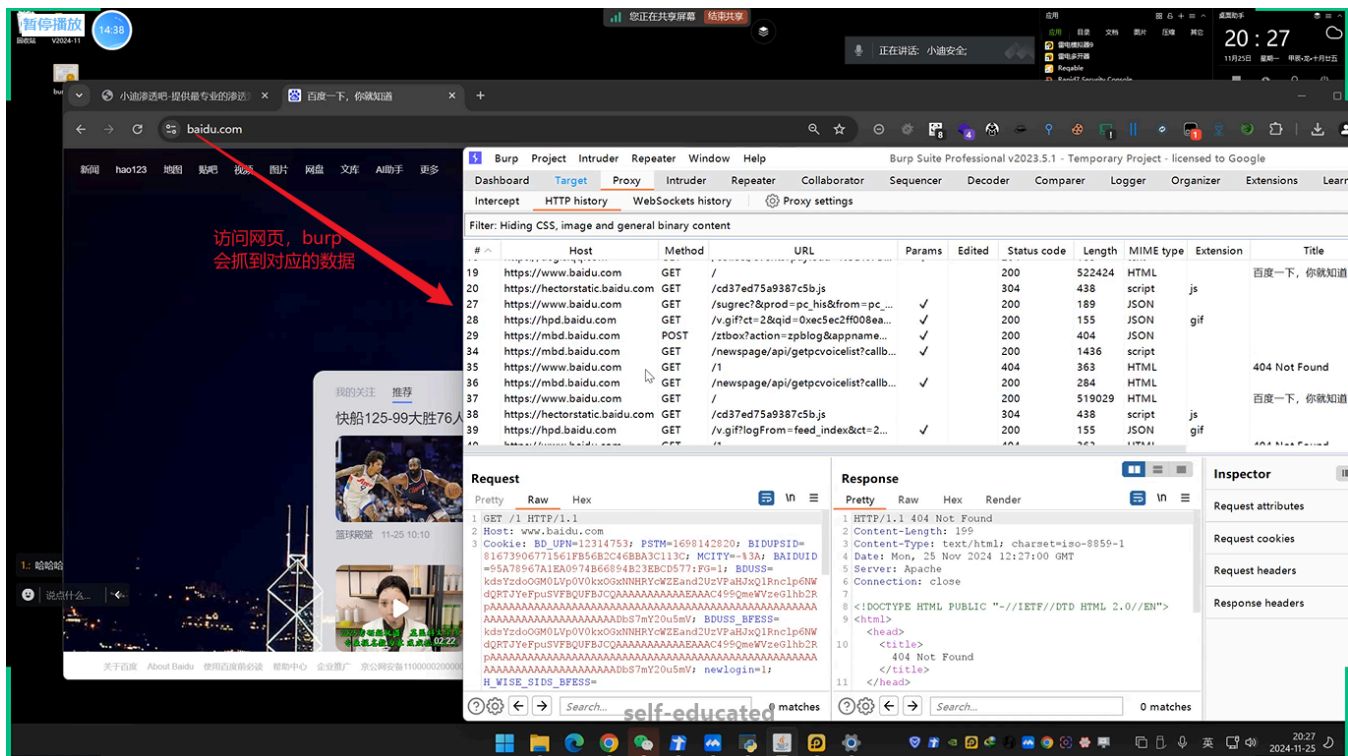






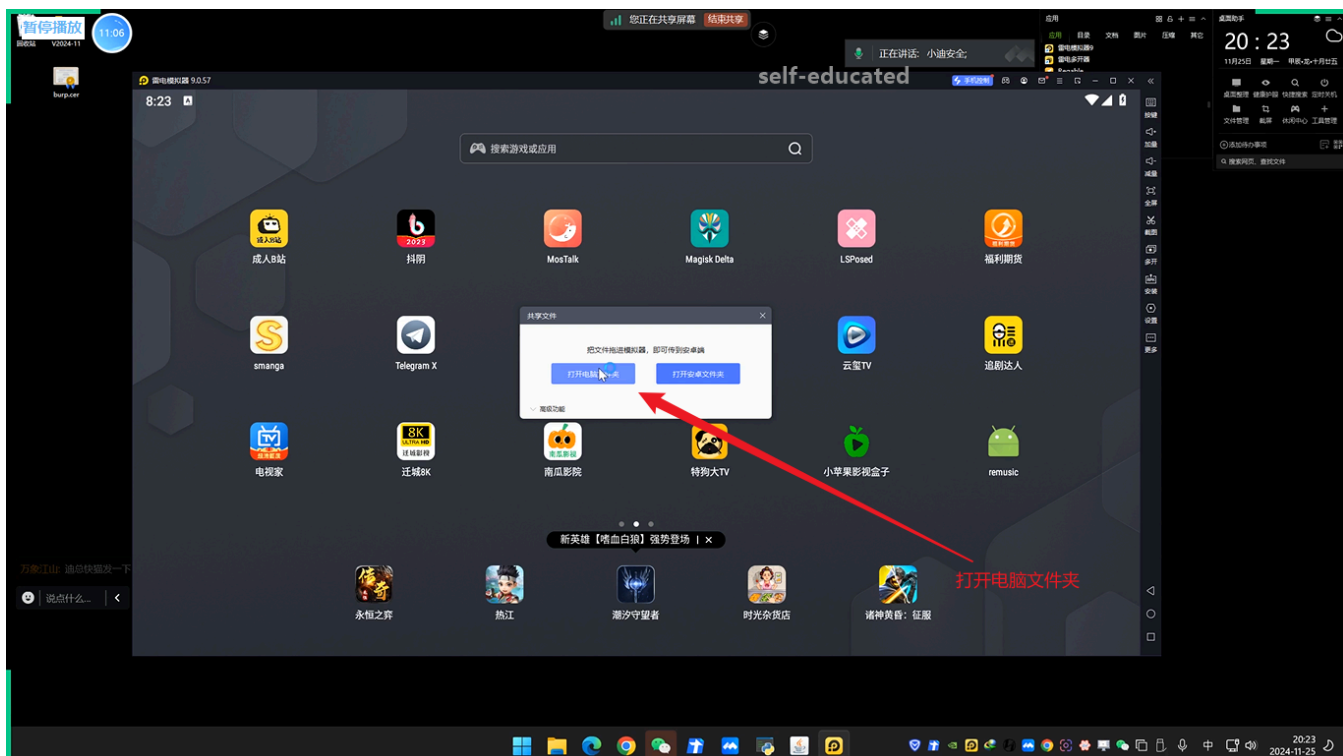
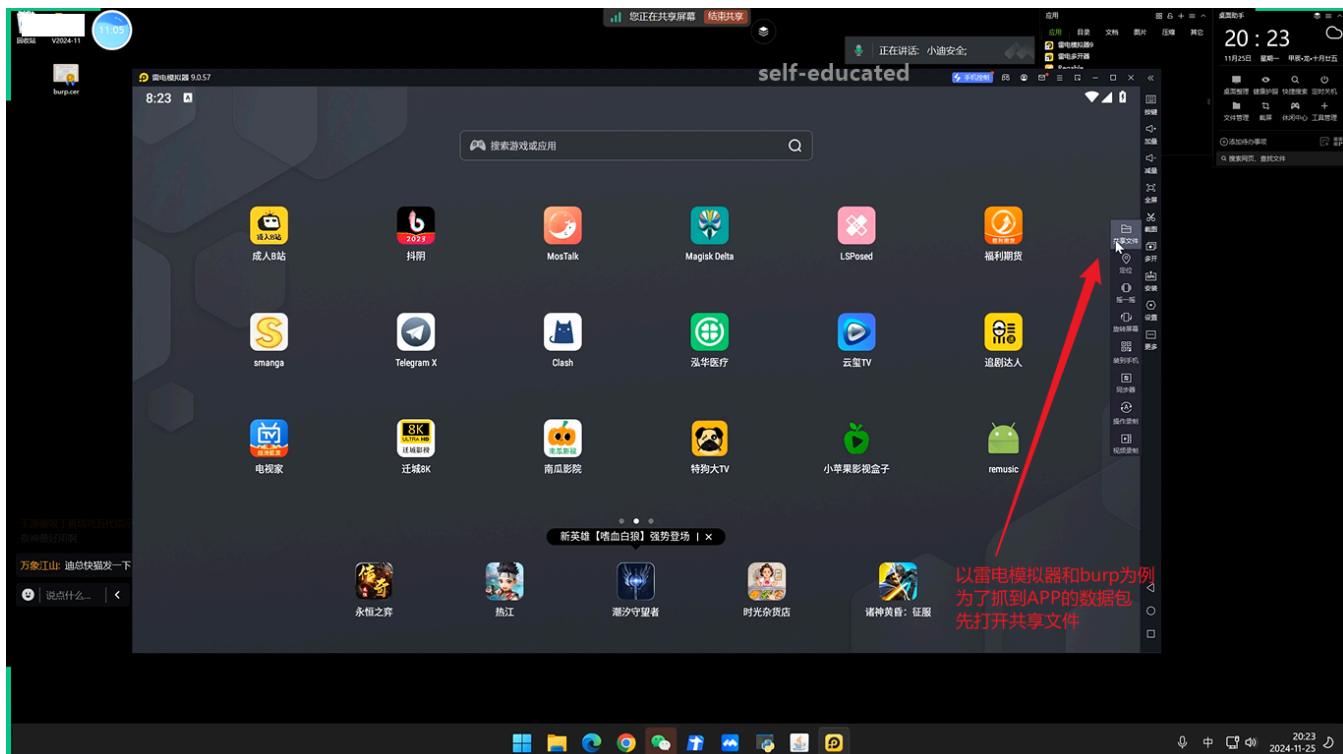
证书配置完成后, 打开burp设置监听端口和IP

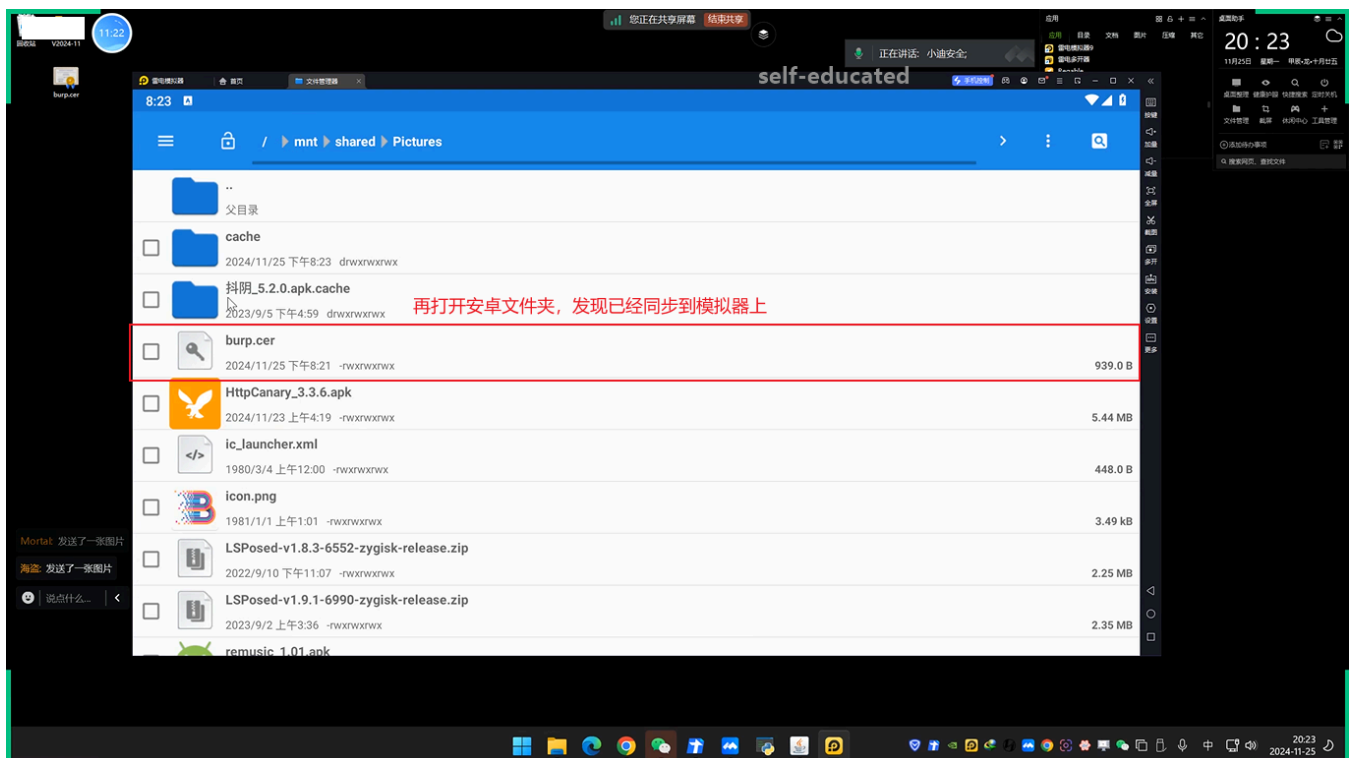
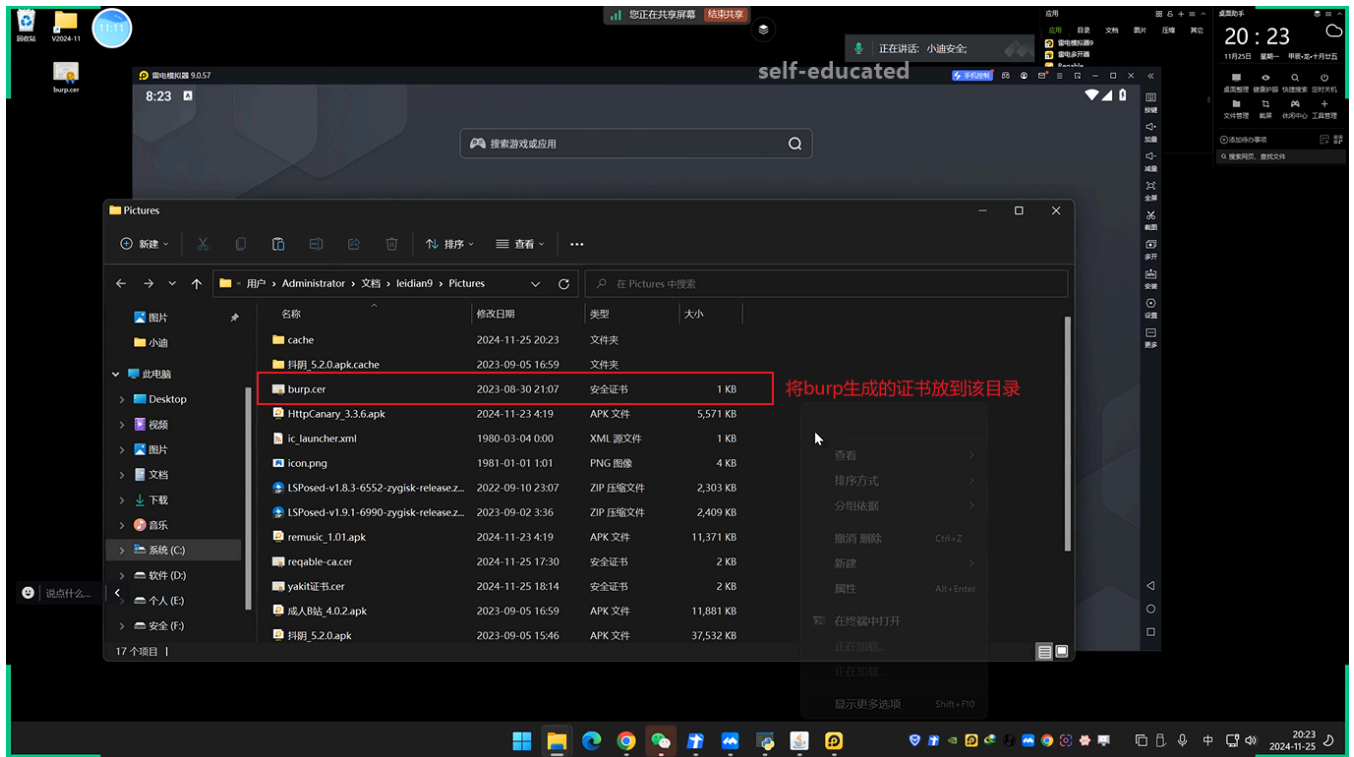


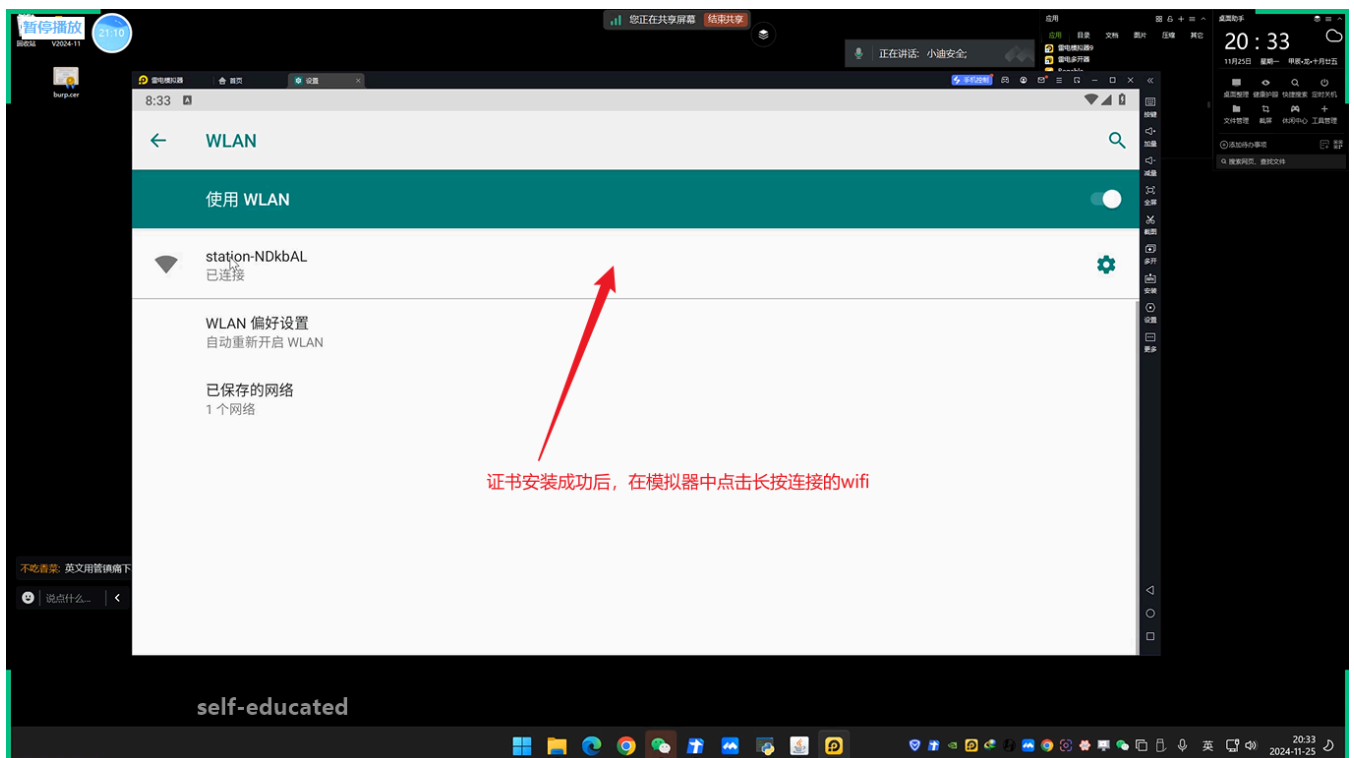
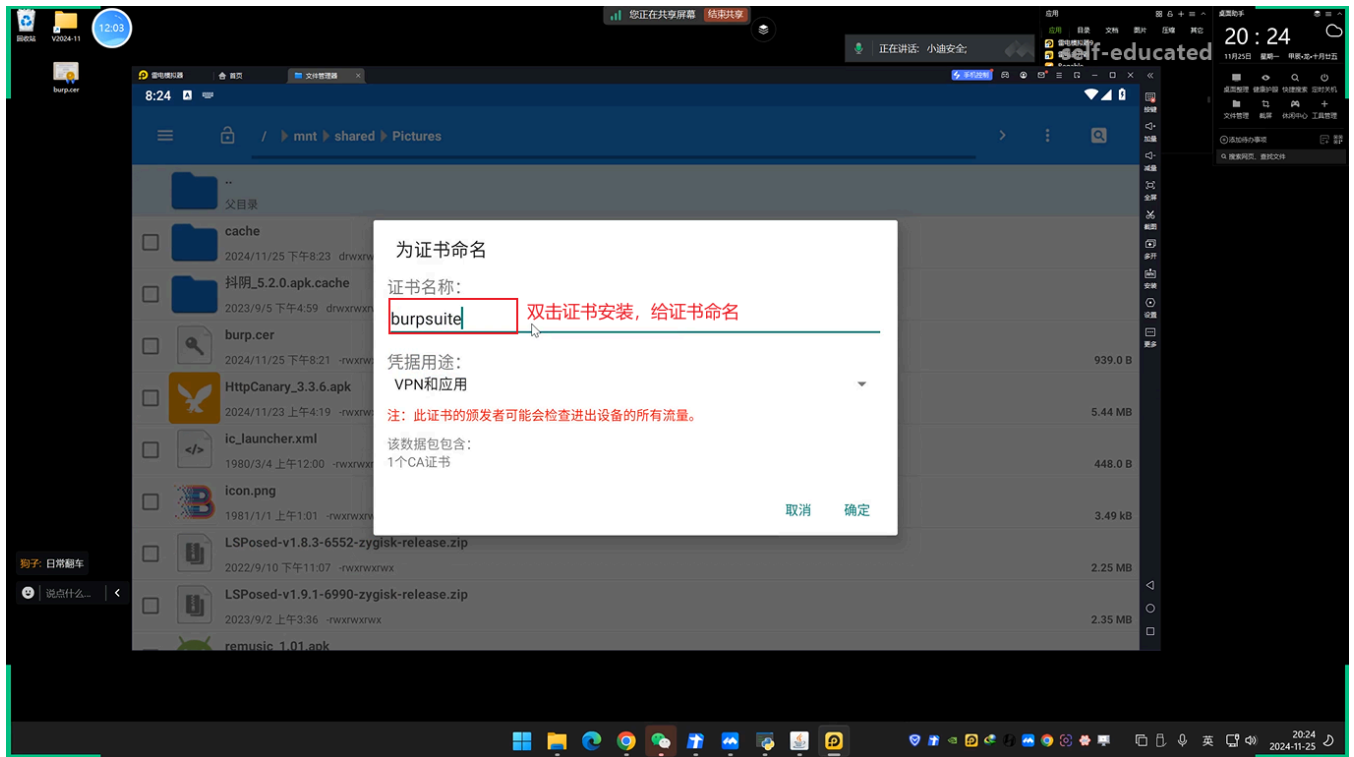


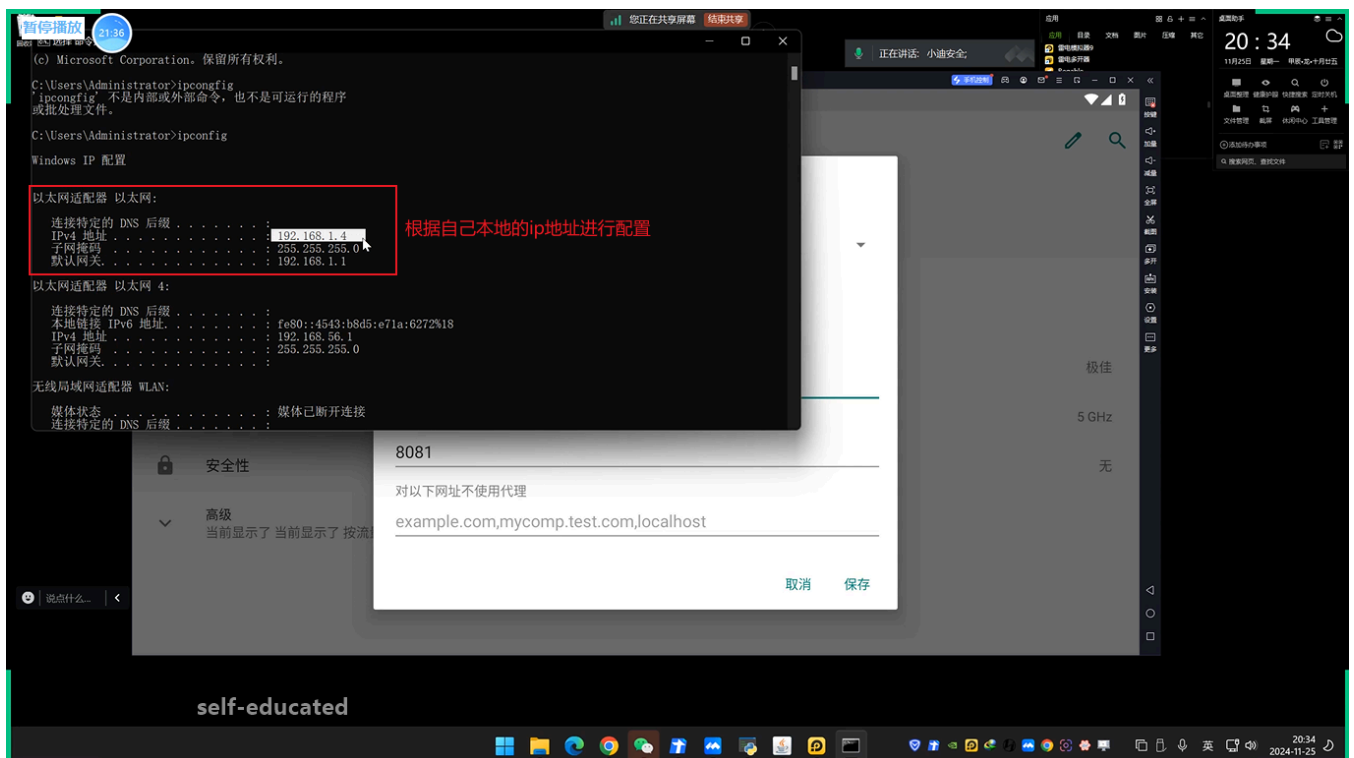
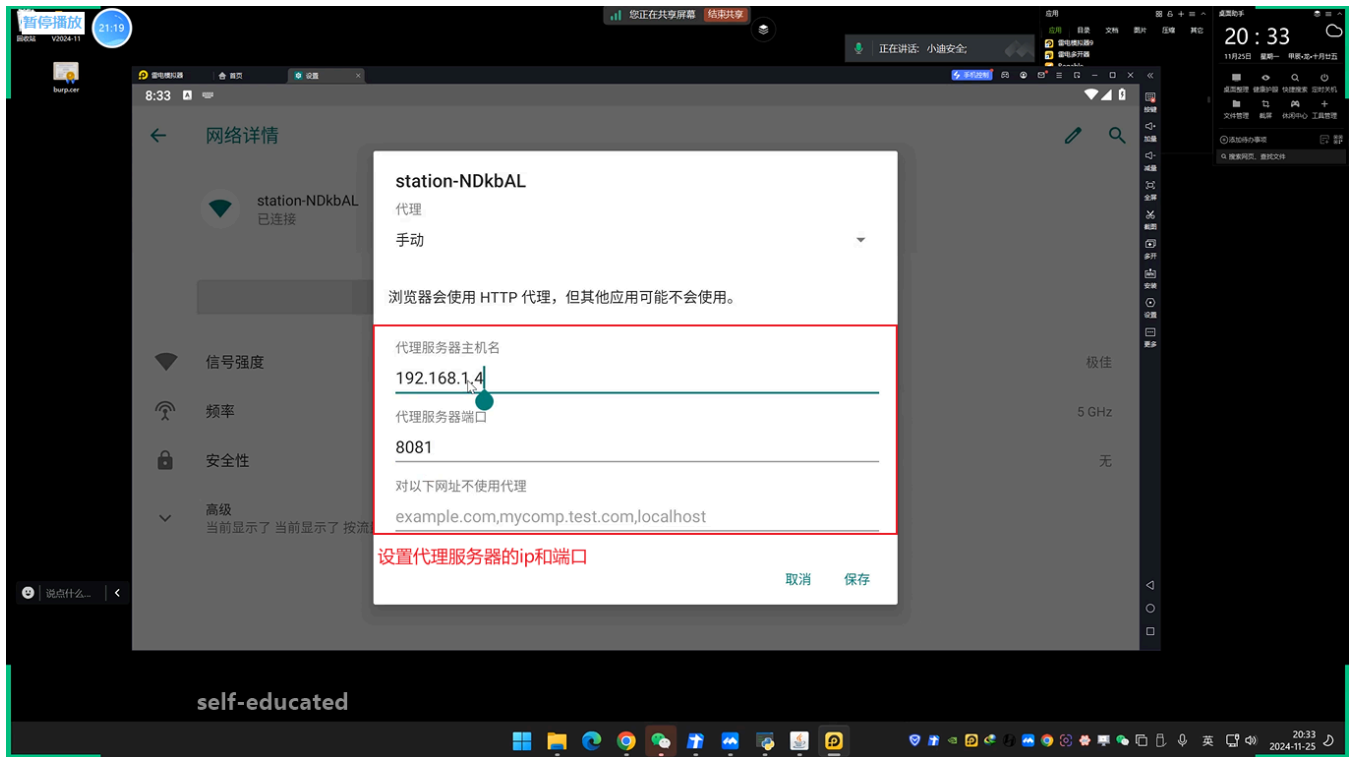
3.1.2 APP-Burp

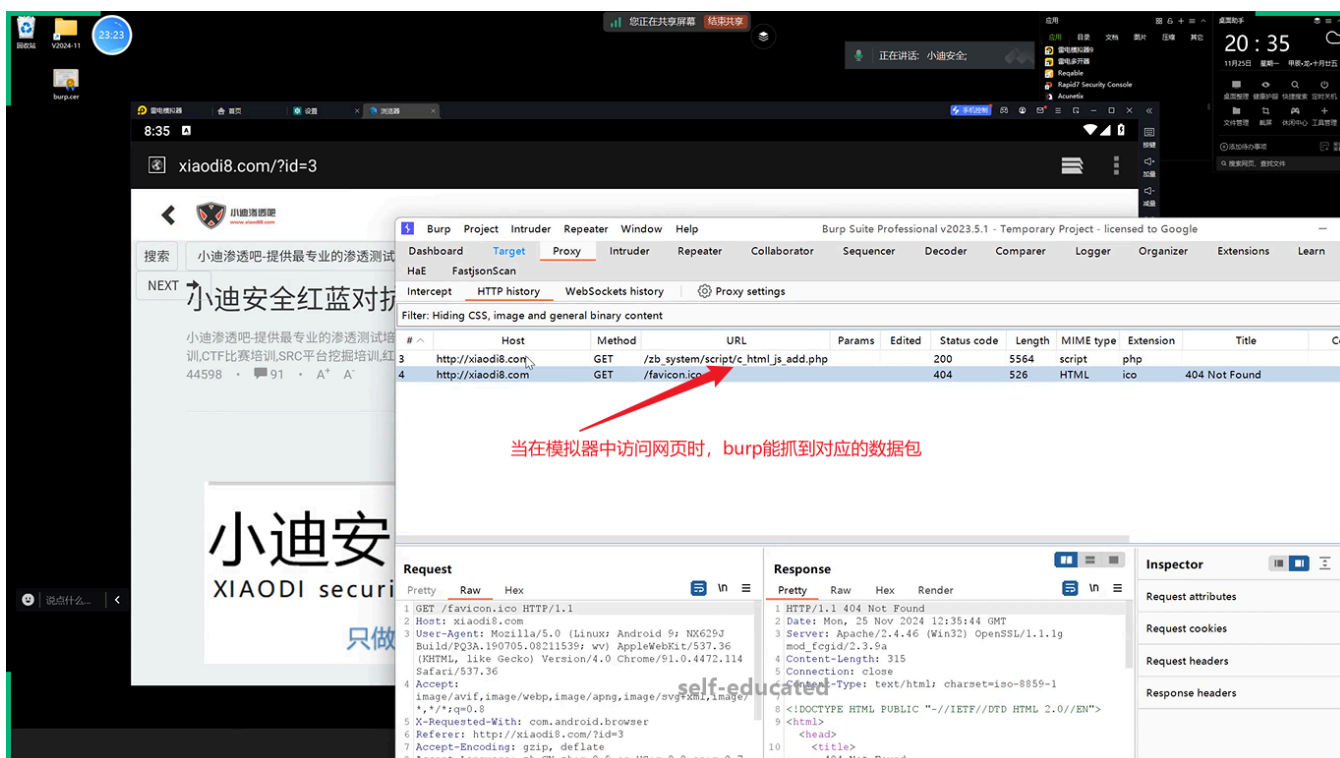
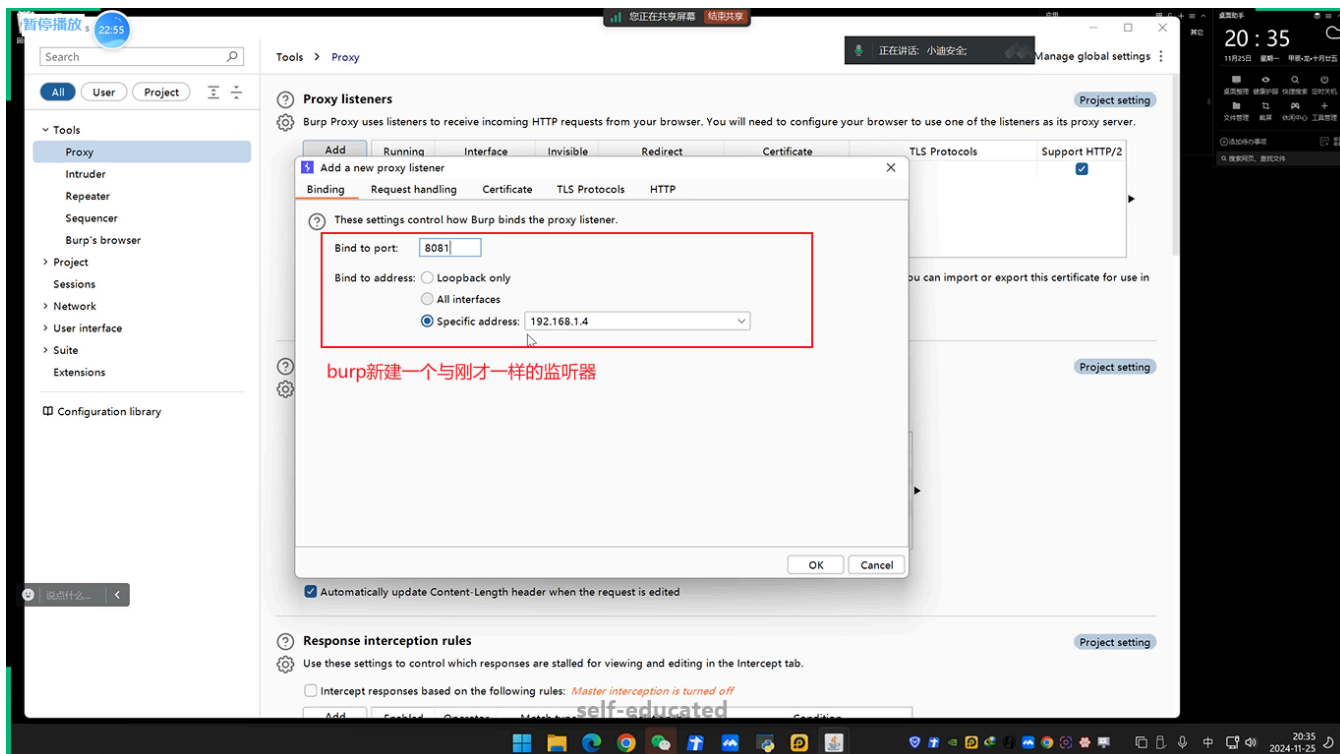
- 1 APP应用
- 1、无防护-模拟器直接抓包
- 2、有防护-真机绕过&更改内核
- 3、有防护-证书绕过&代理绕过
- 5 注意: 真机抓包要保证手机和电脑在同一网络

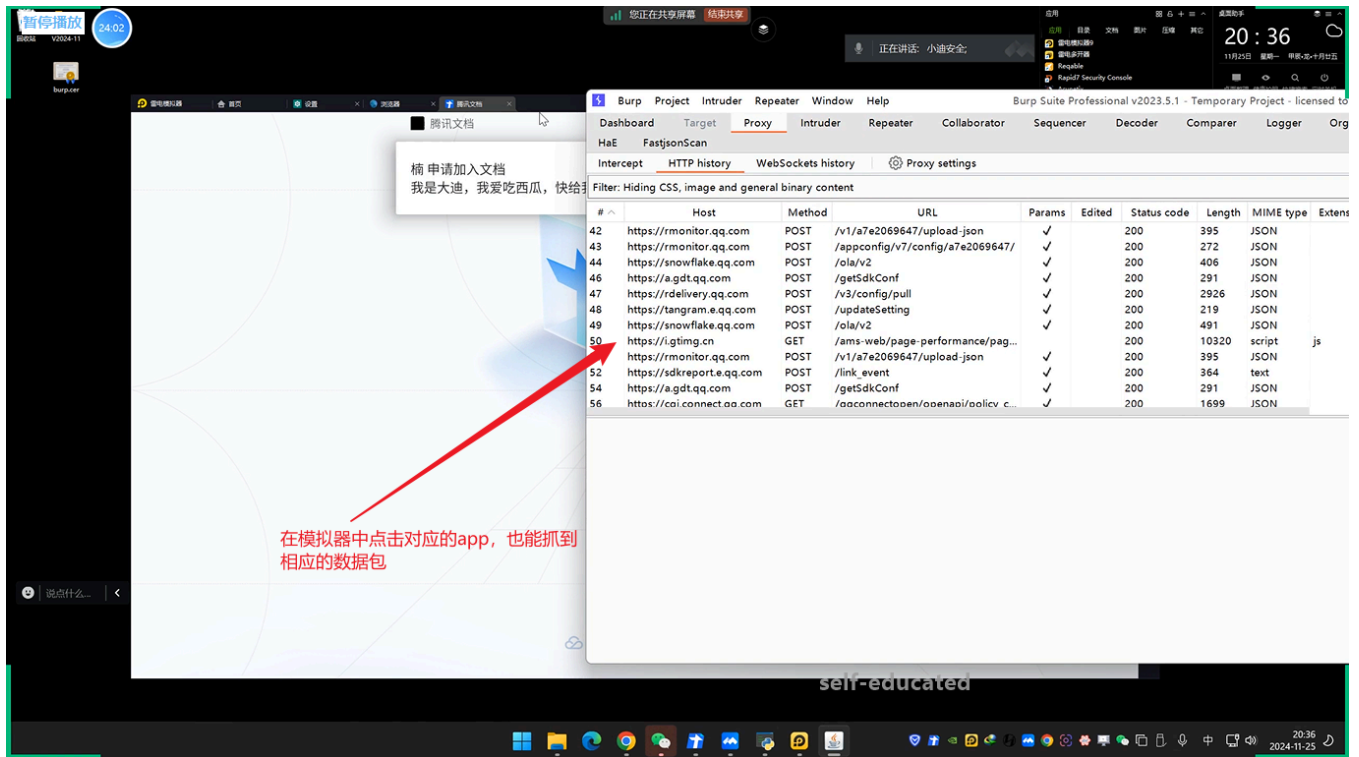




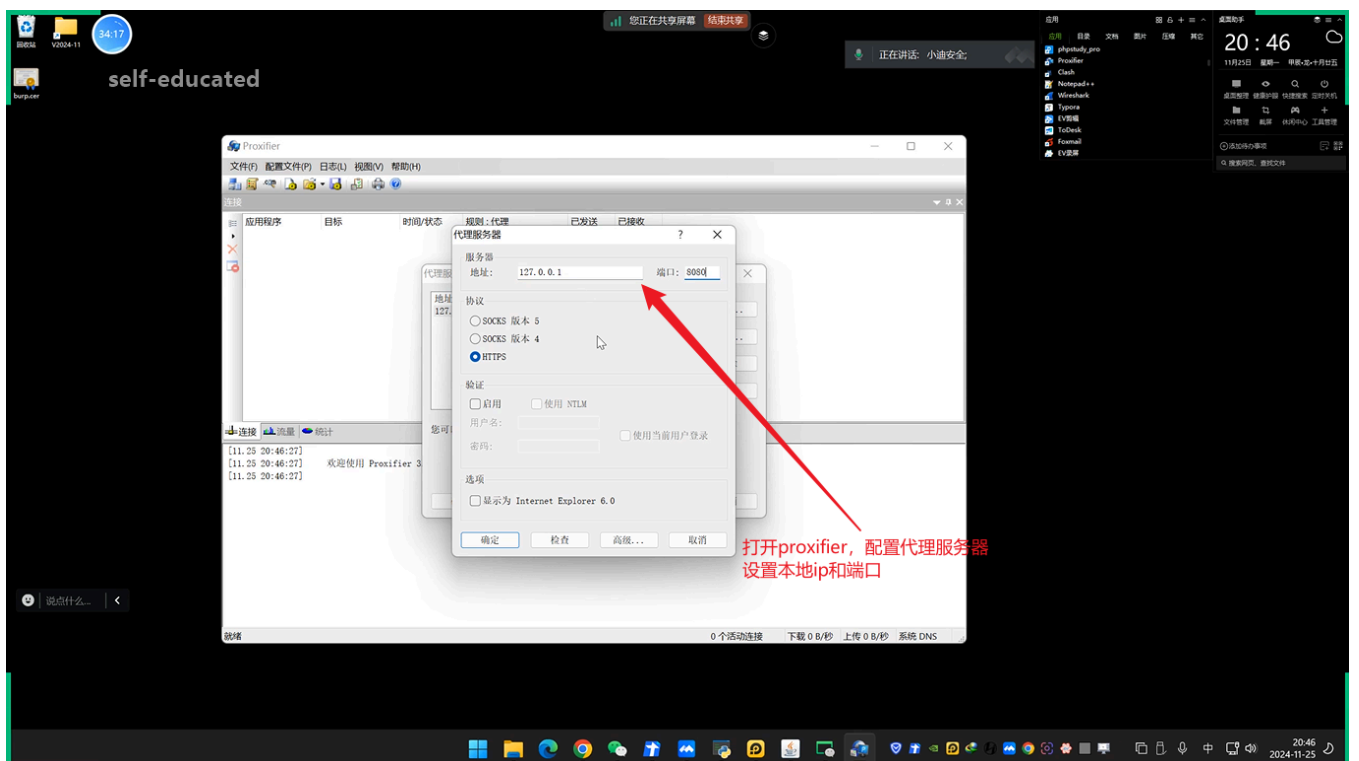


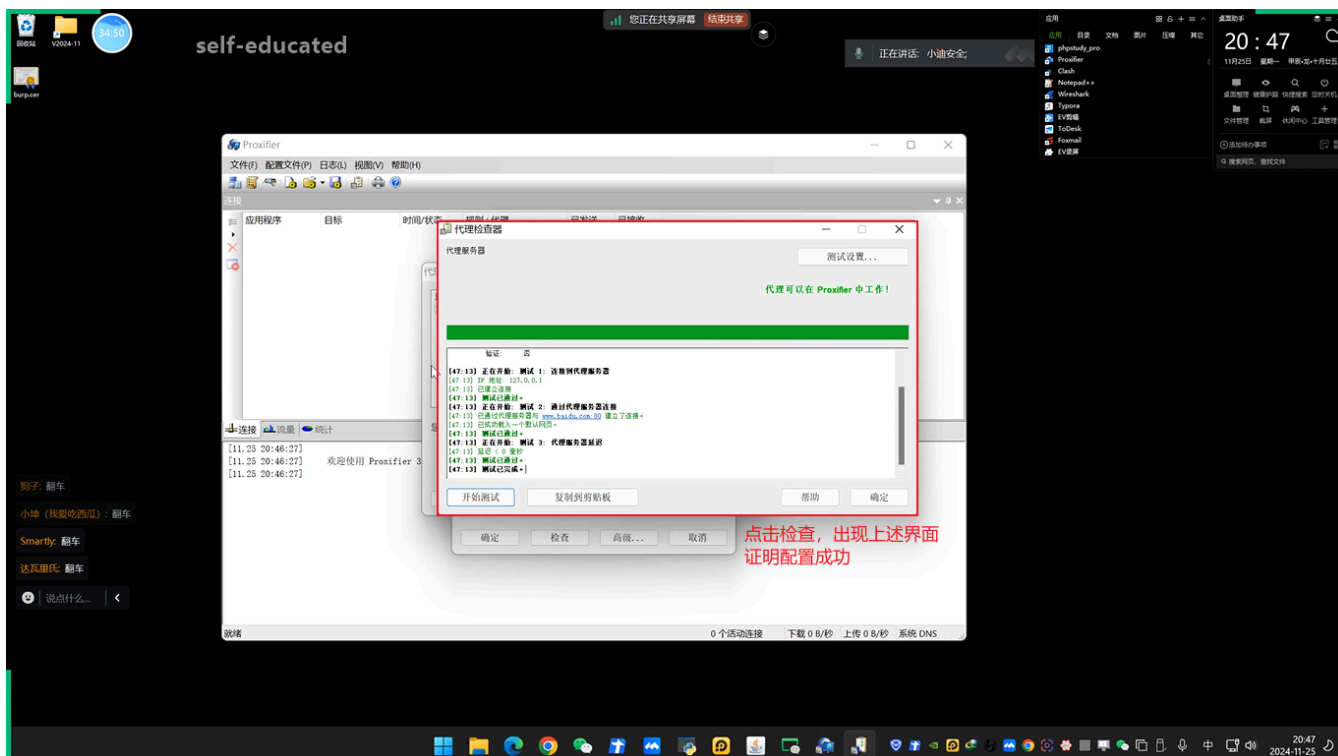
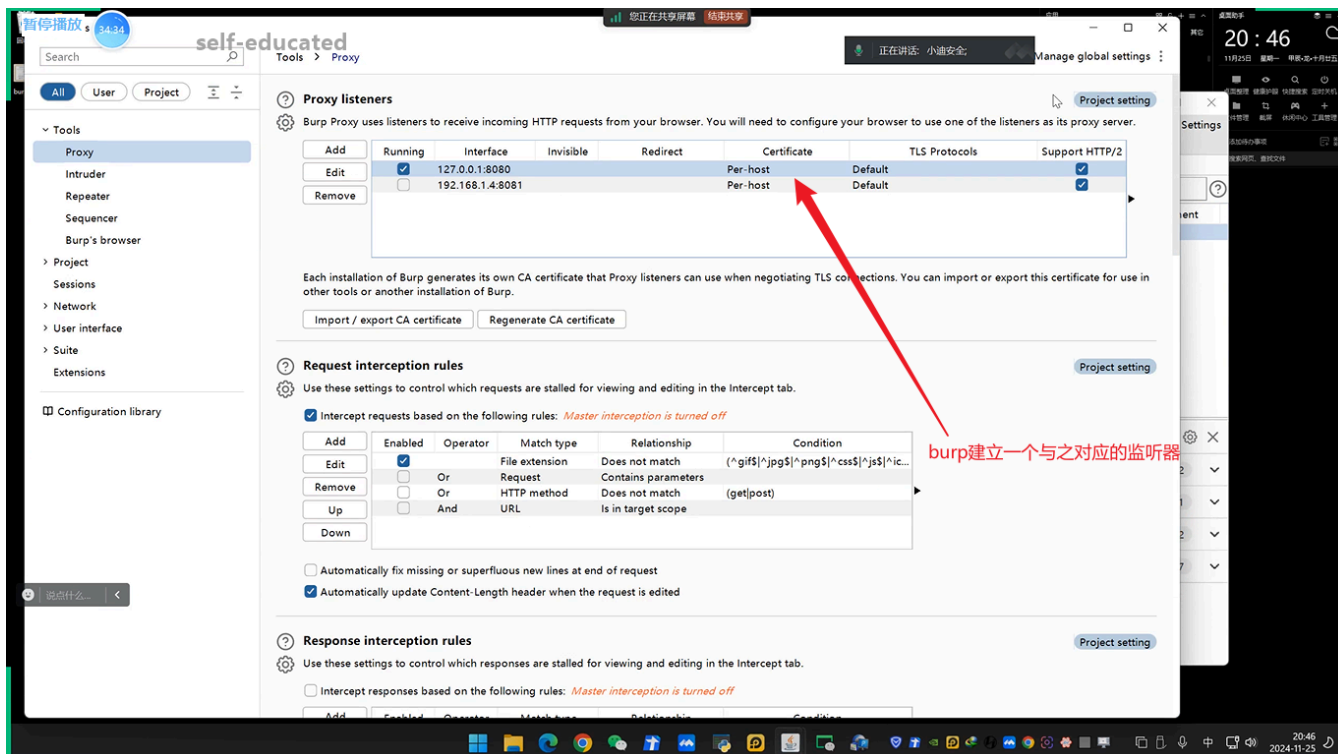


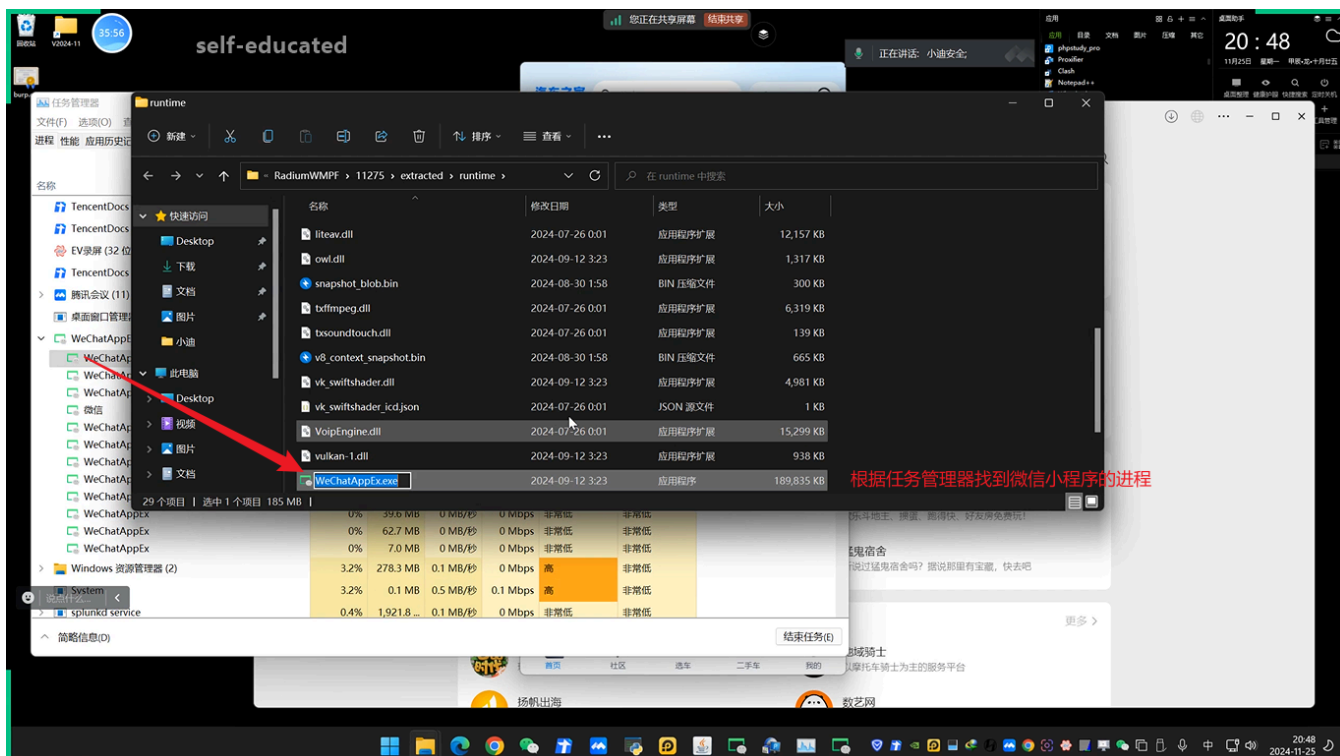
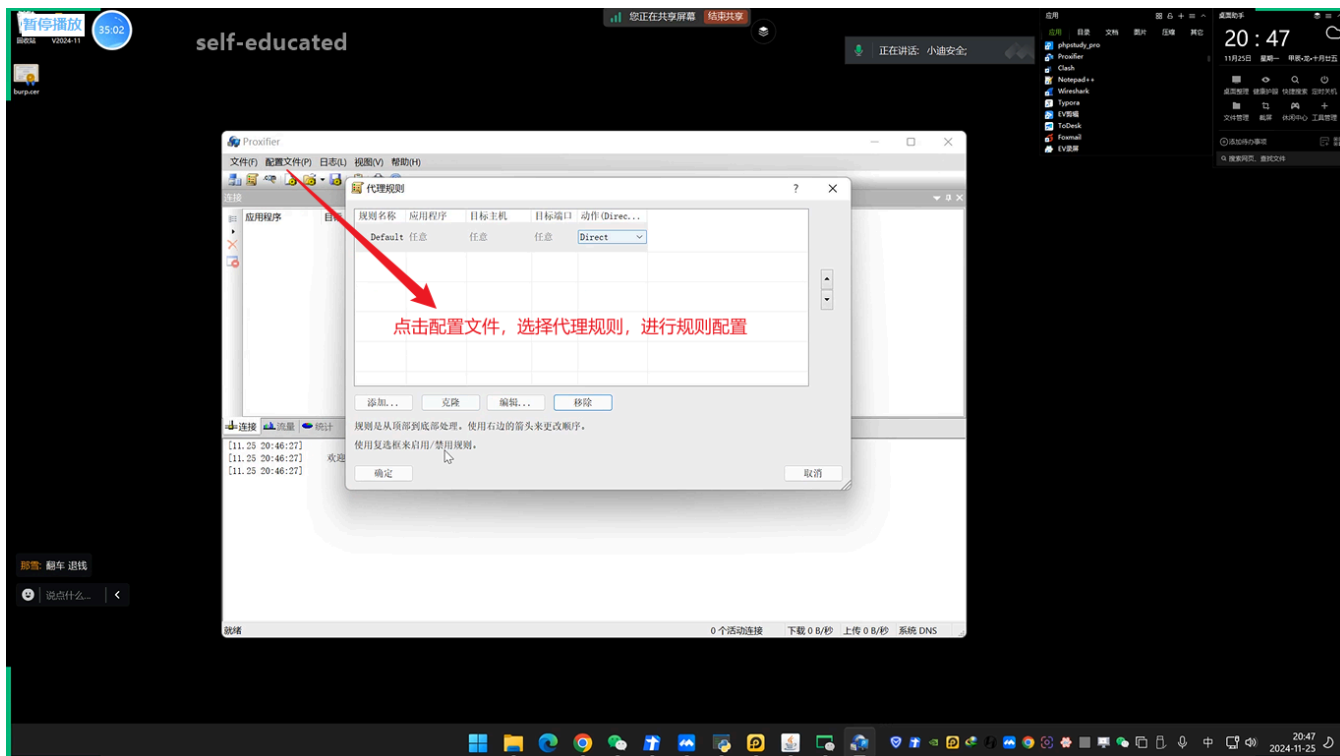


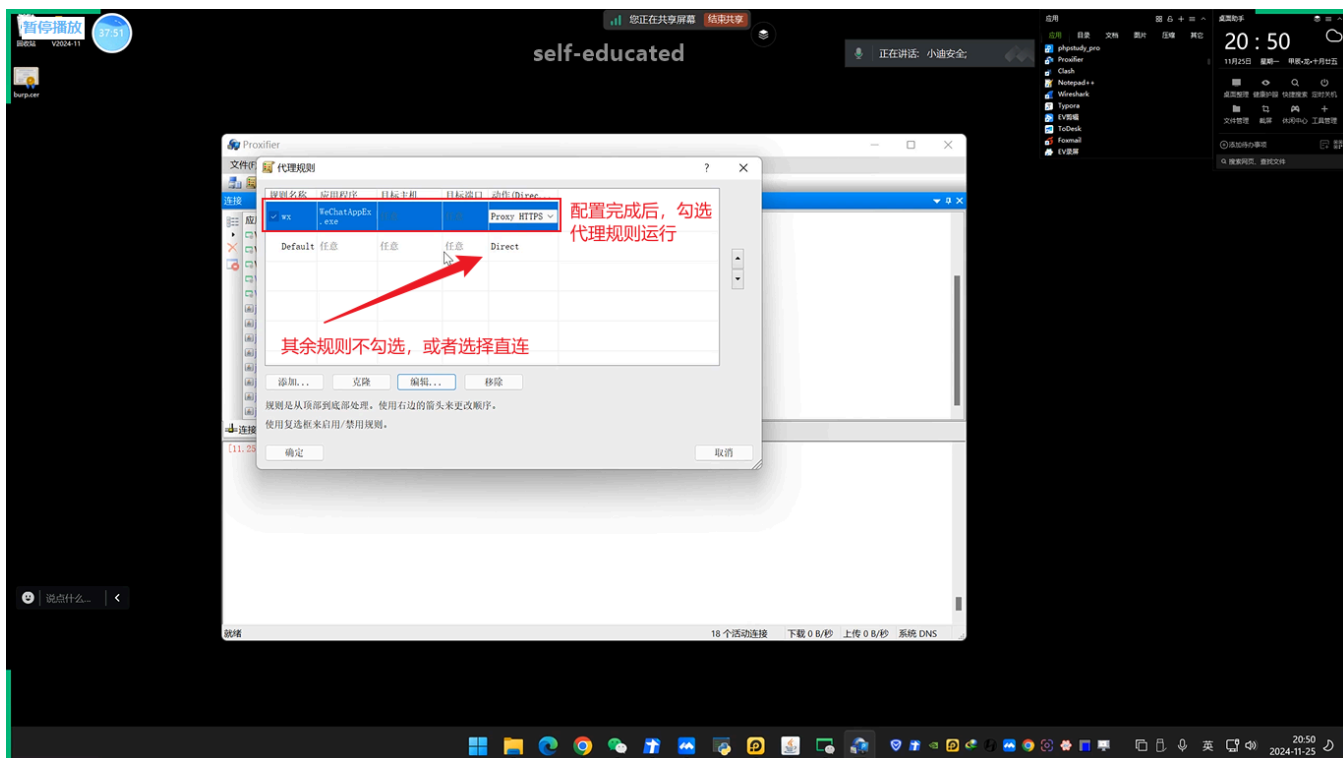
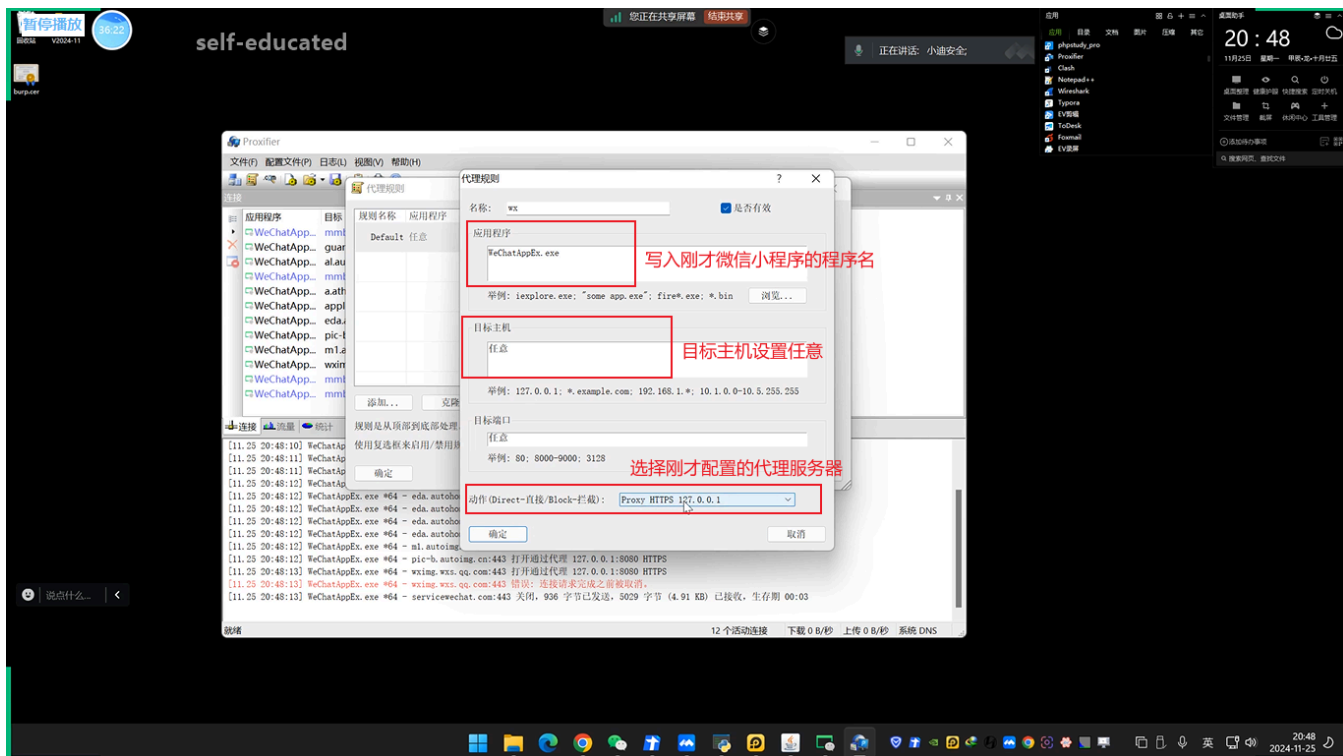


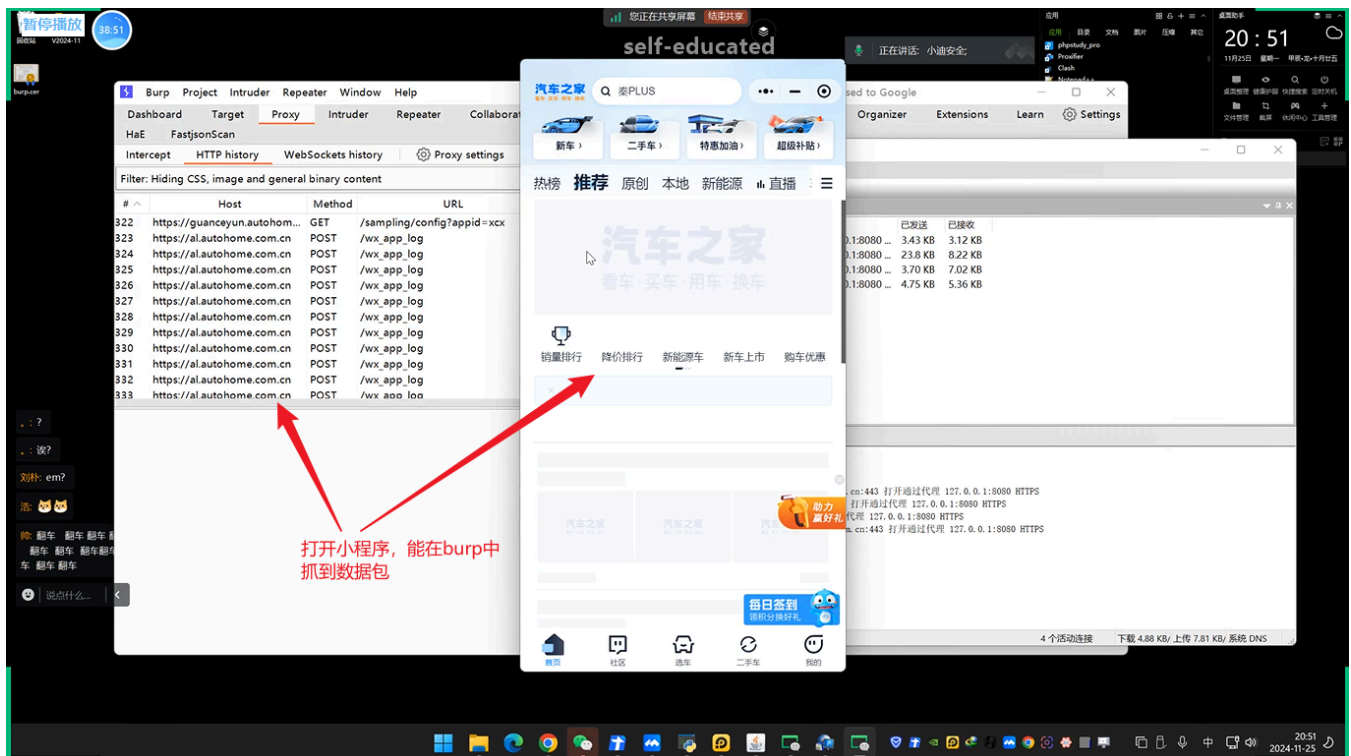
3.1.3 小程序-Burp





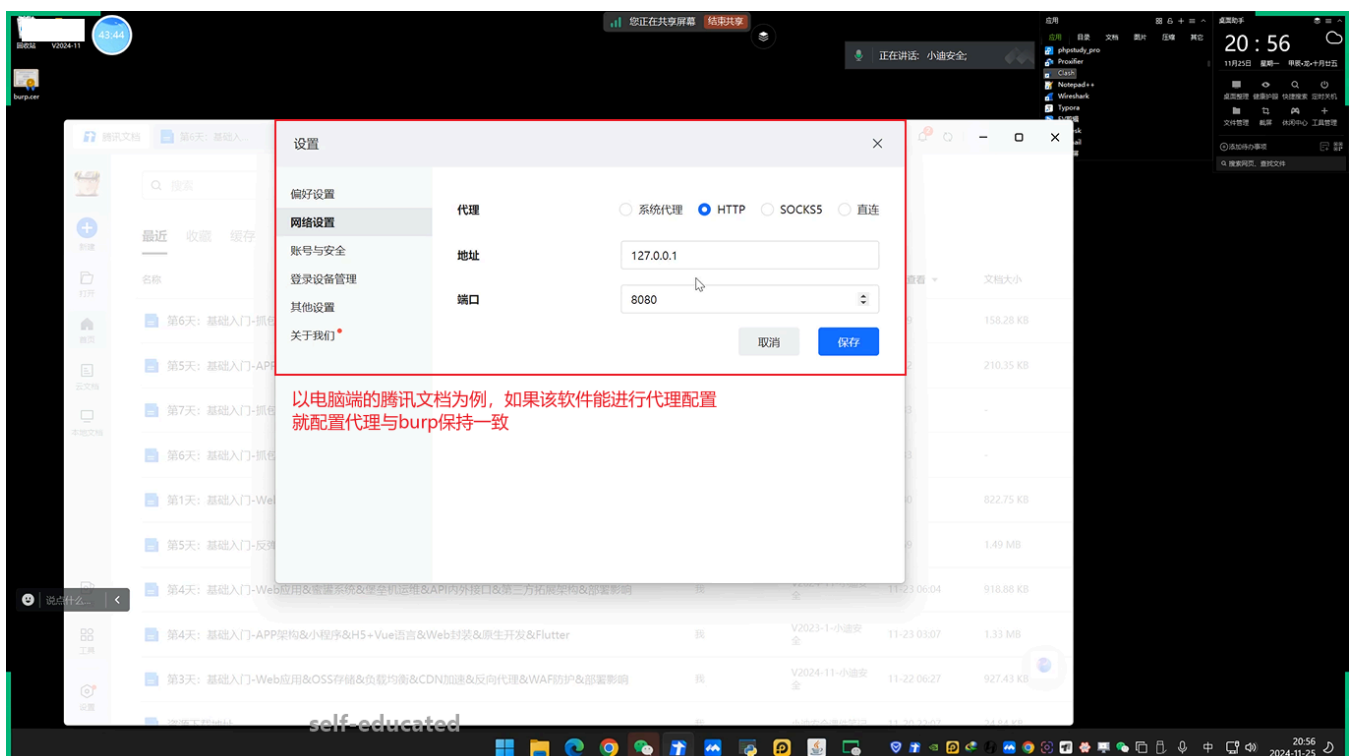


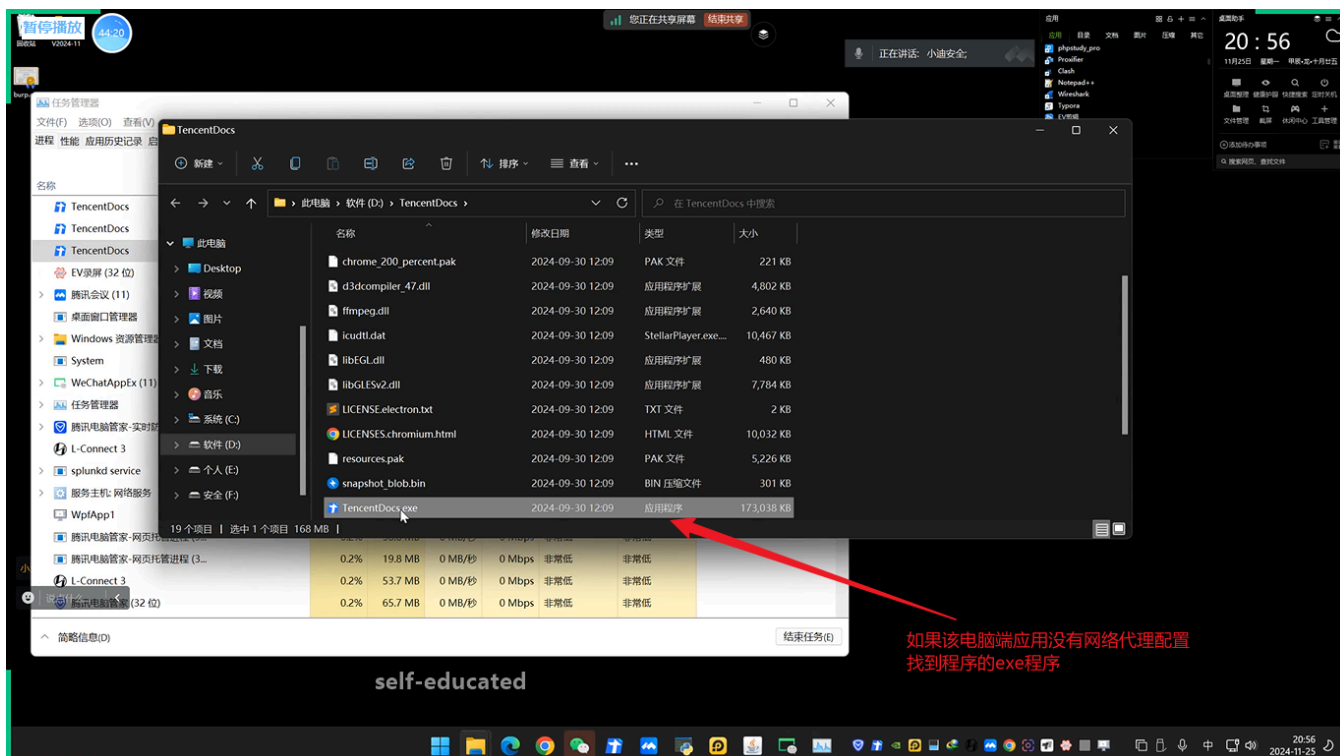
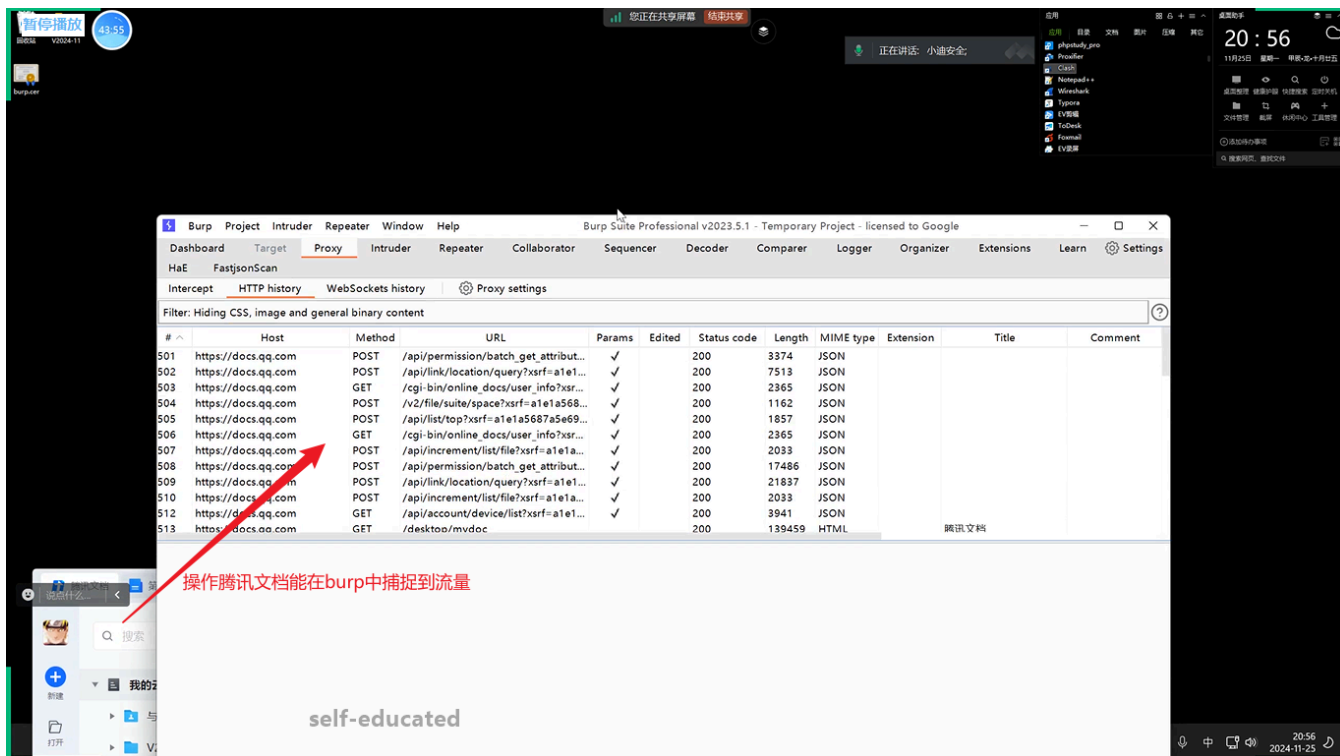


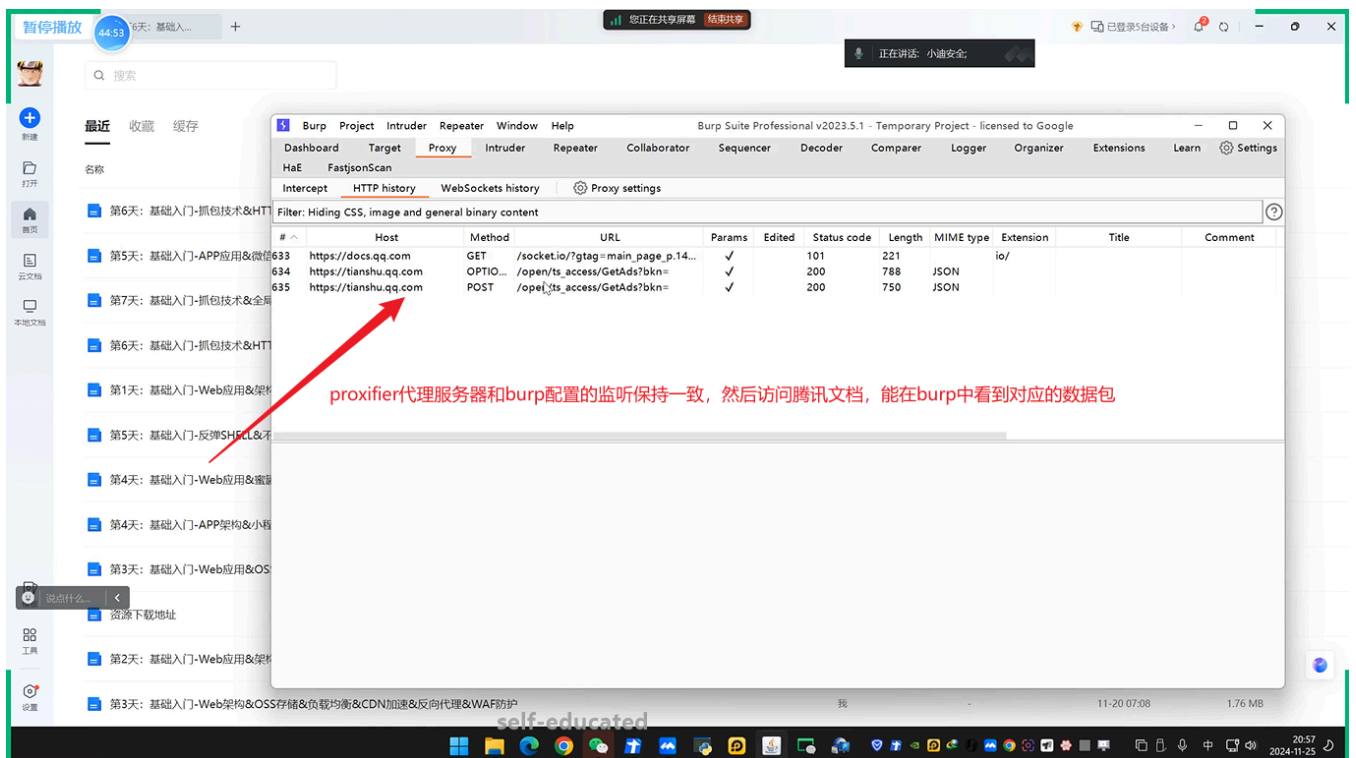
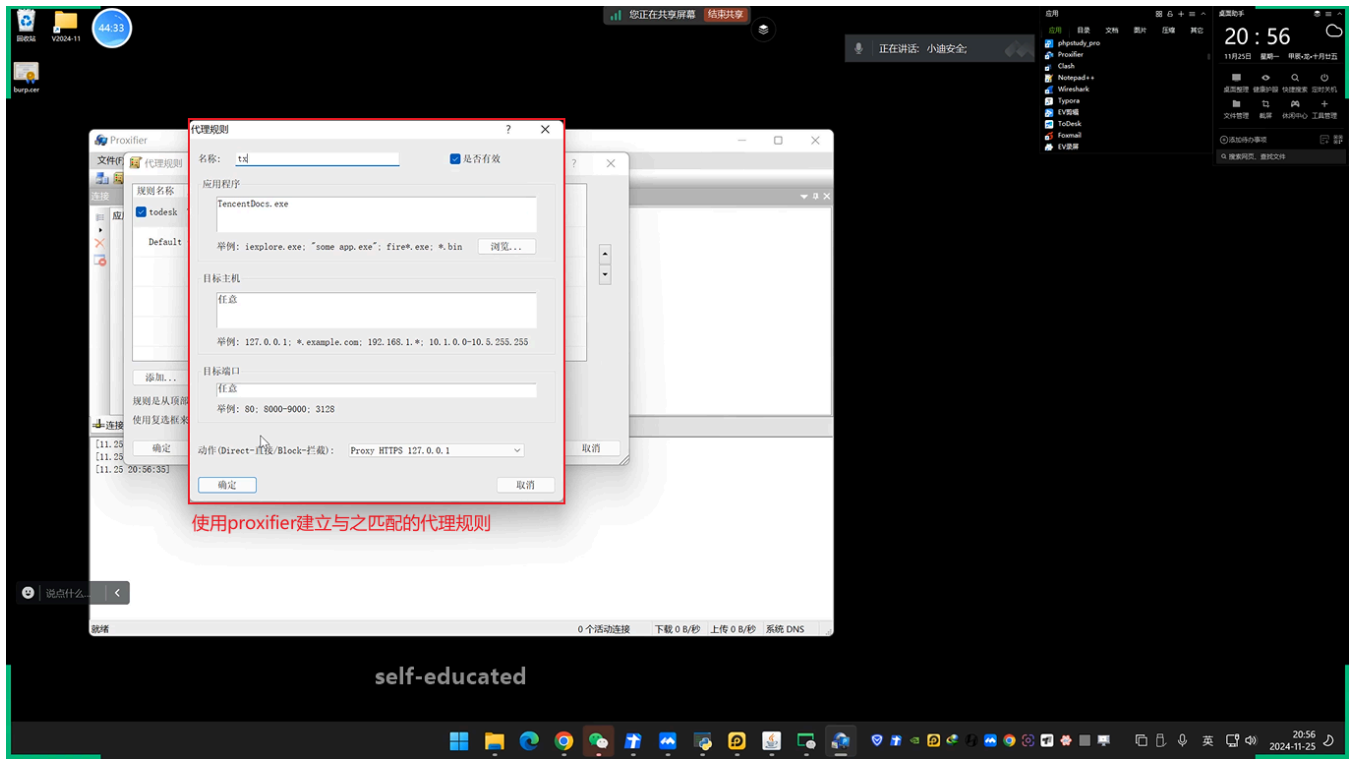


3.1.4 PC-Burp

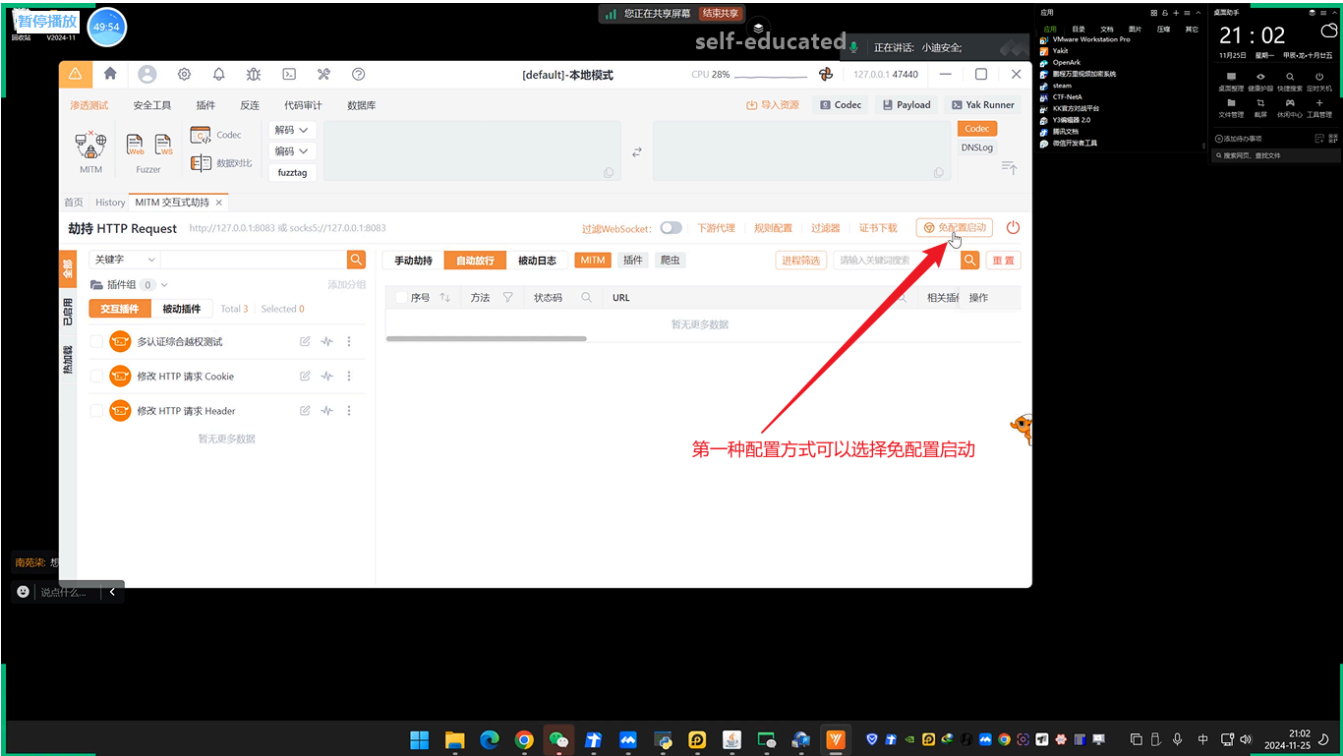
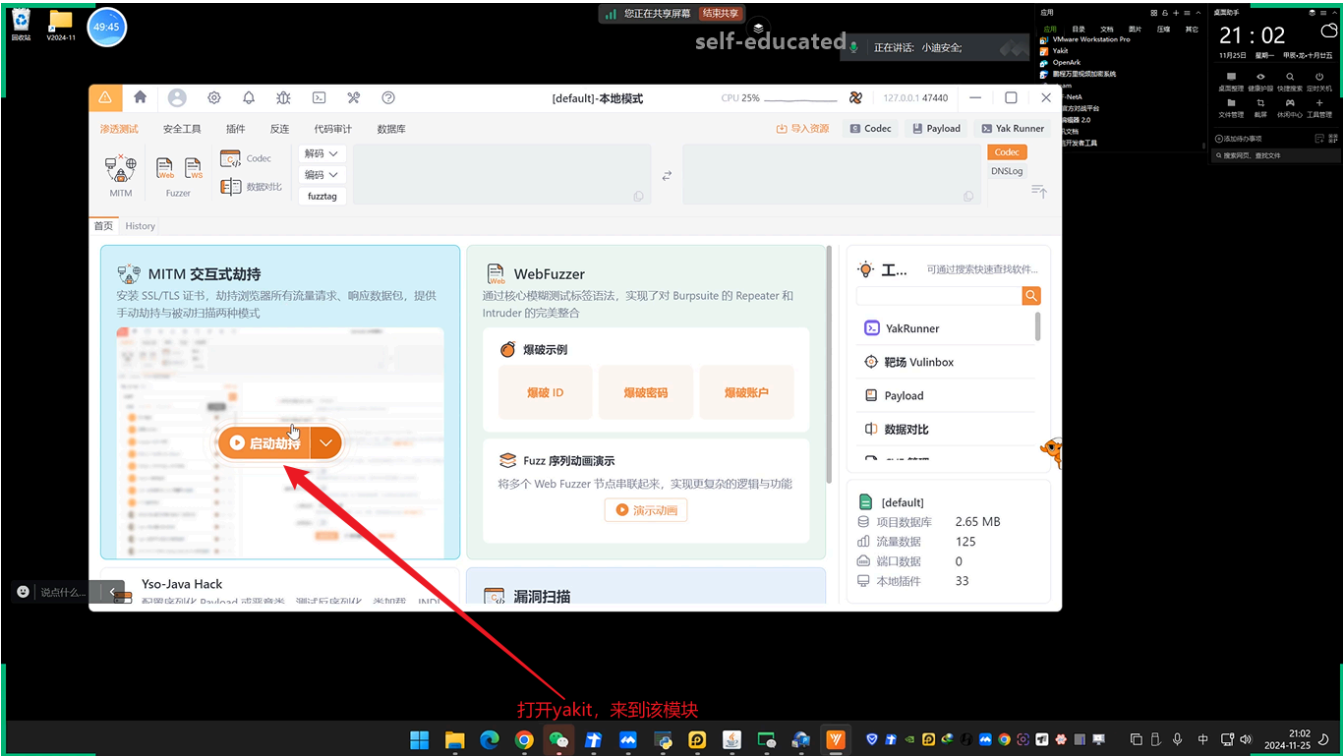
- 1 PC端应用
- 1、有代理设置走代理设置
- 2、没有代理设置走联动转发

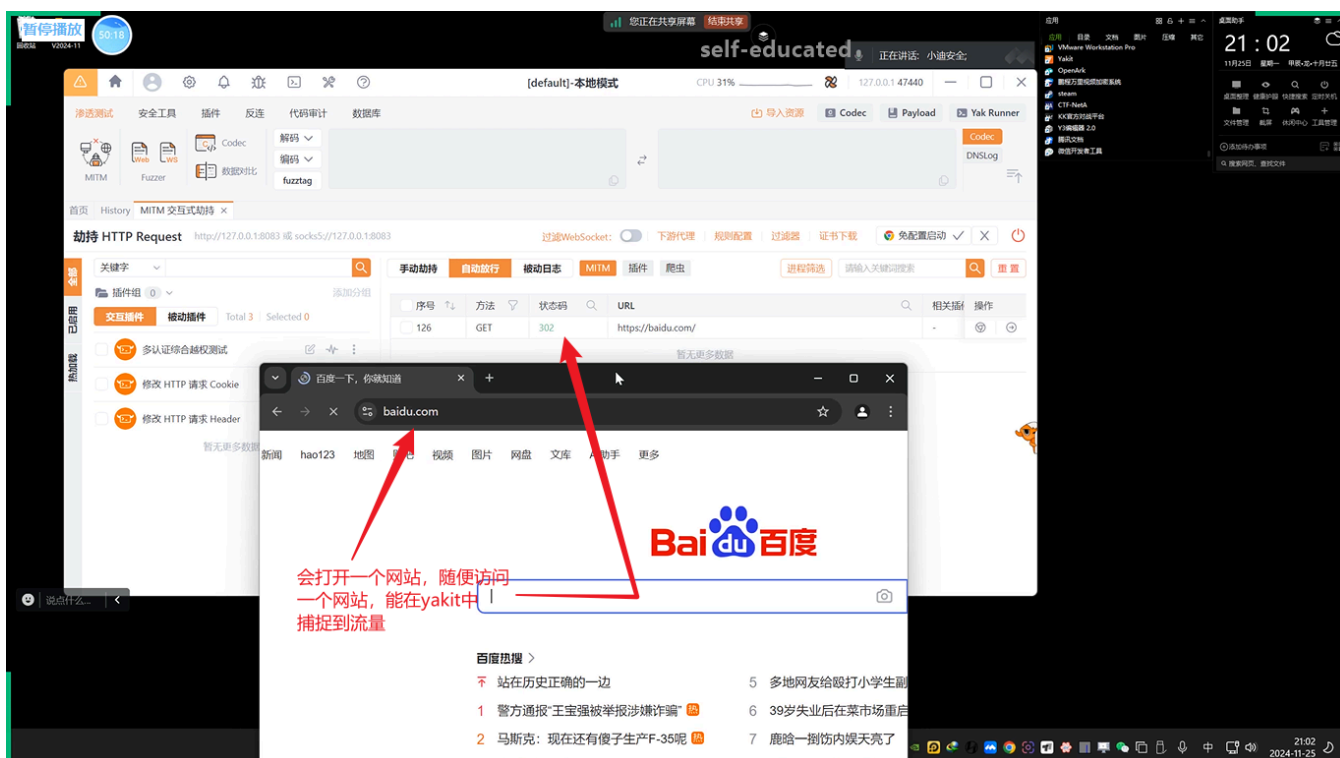
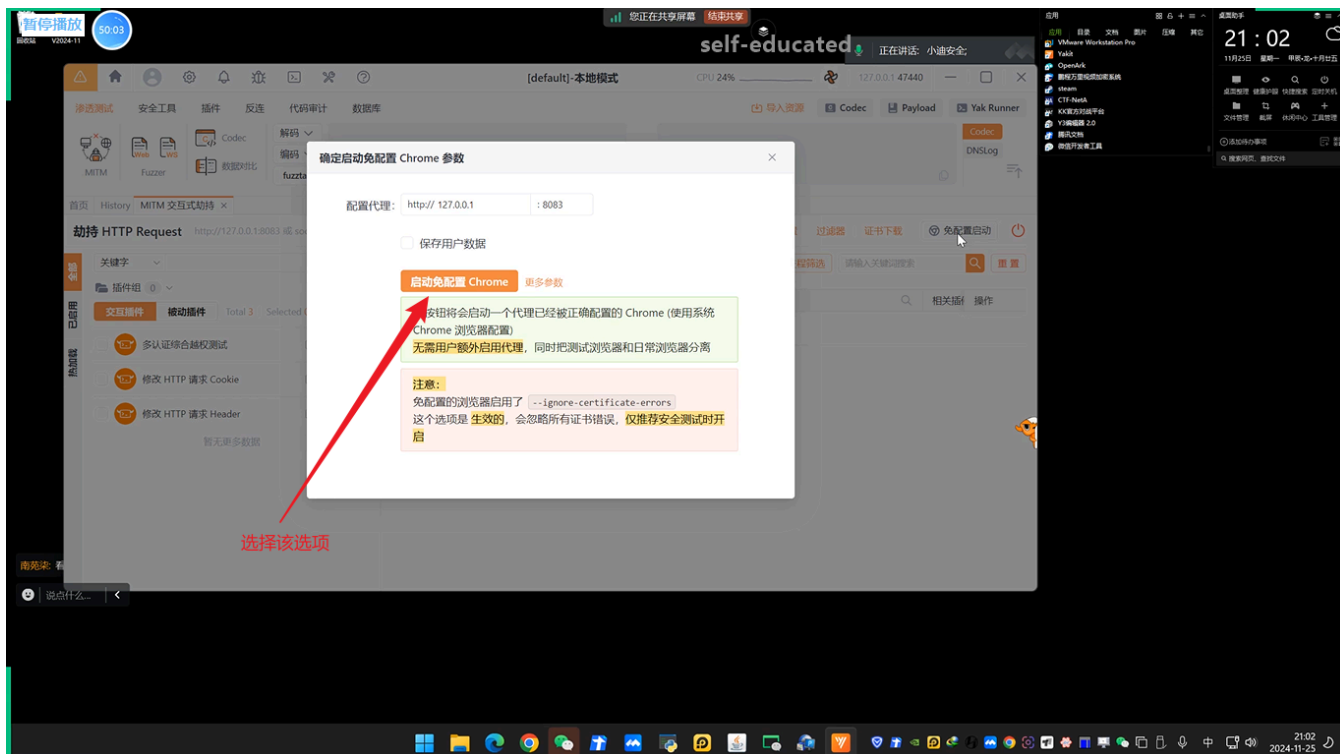


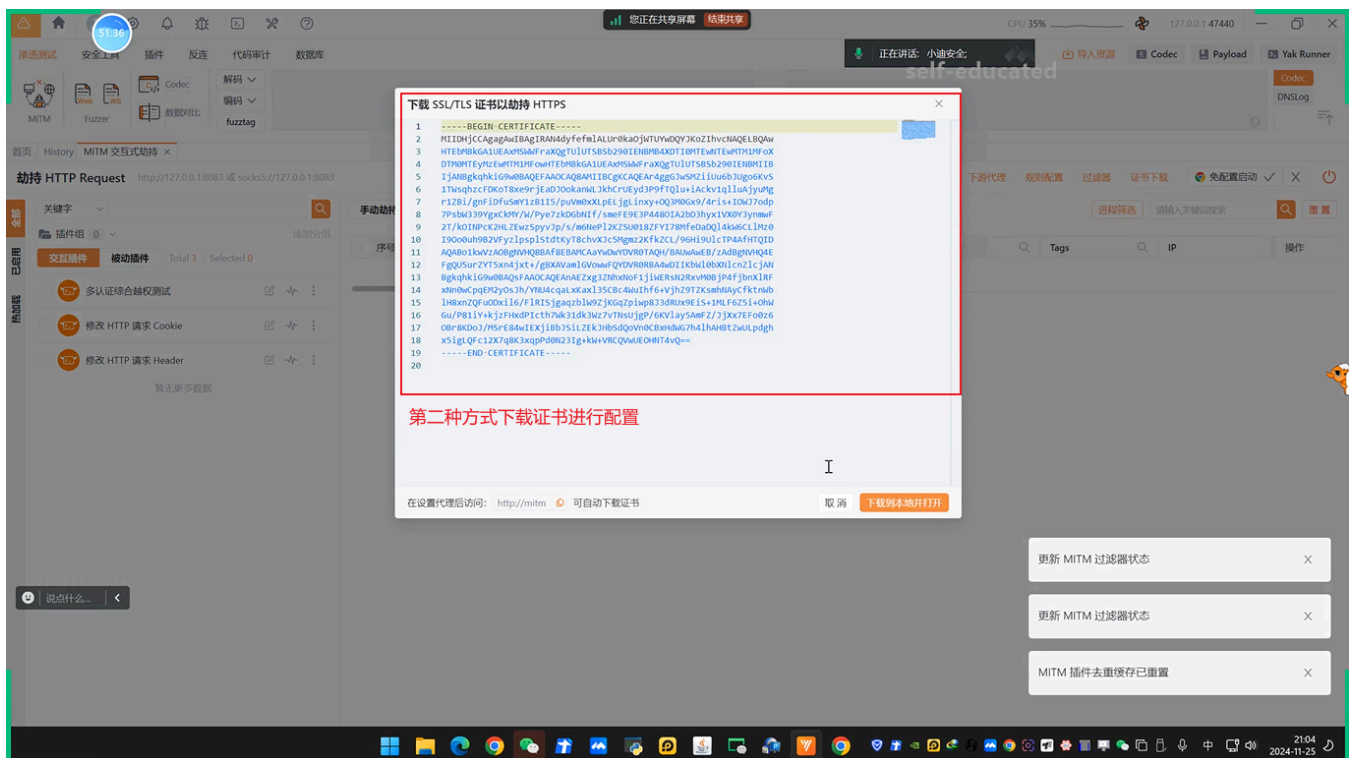
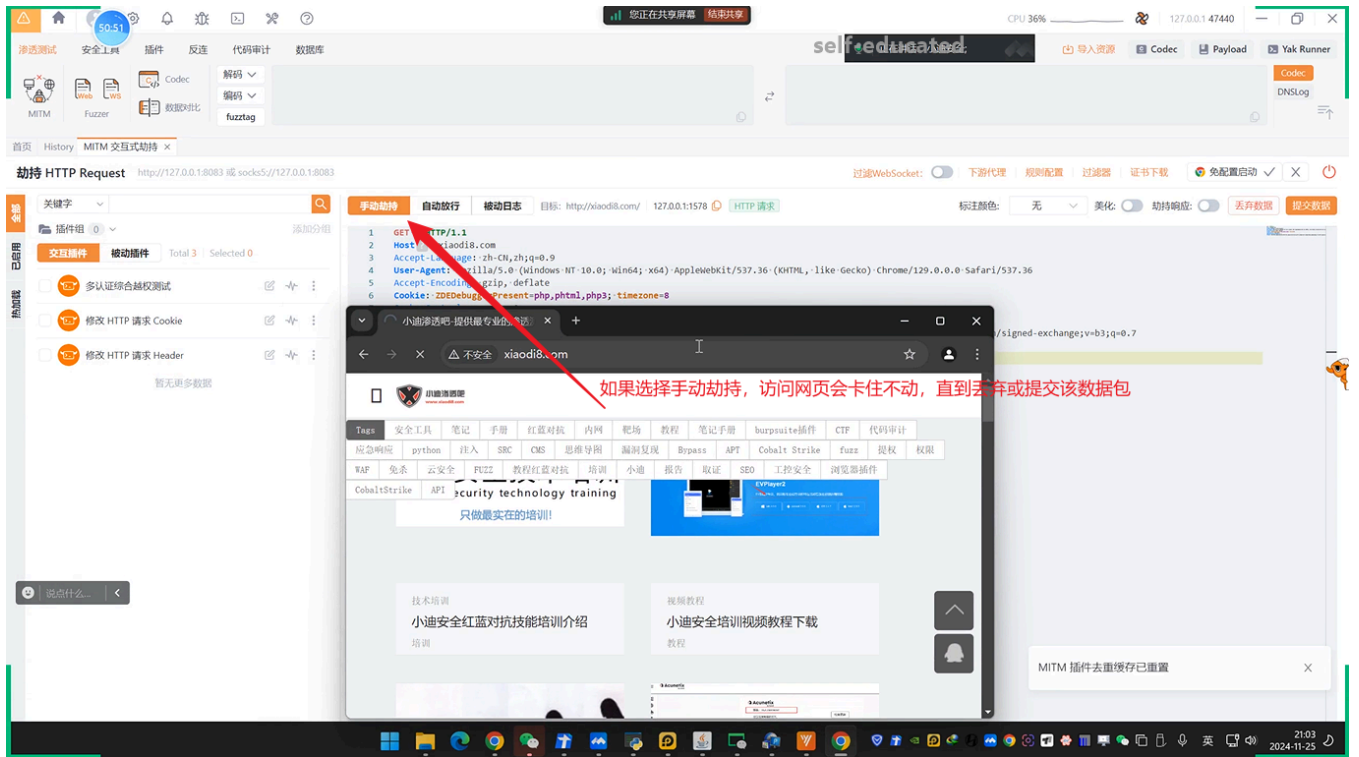


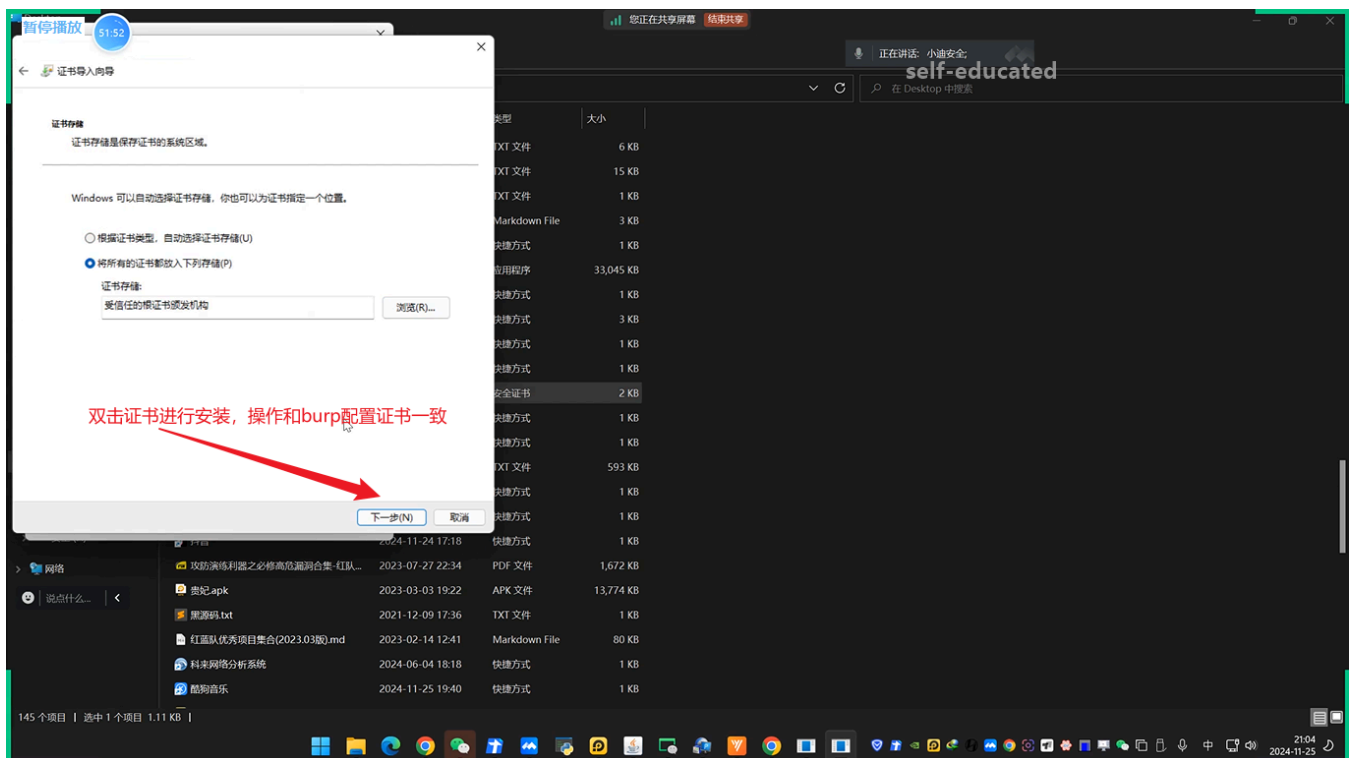
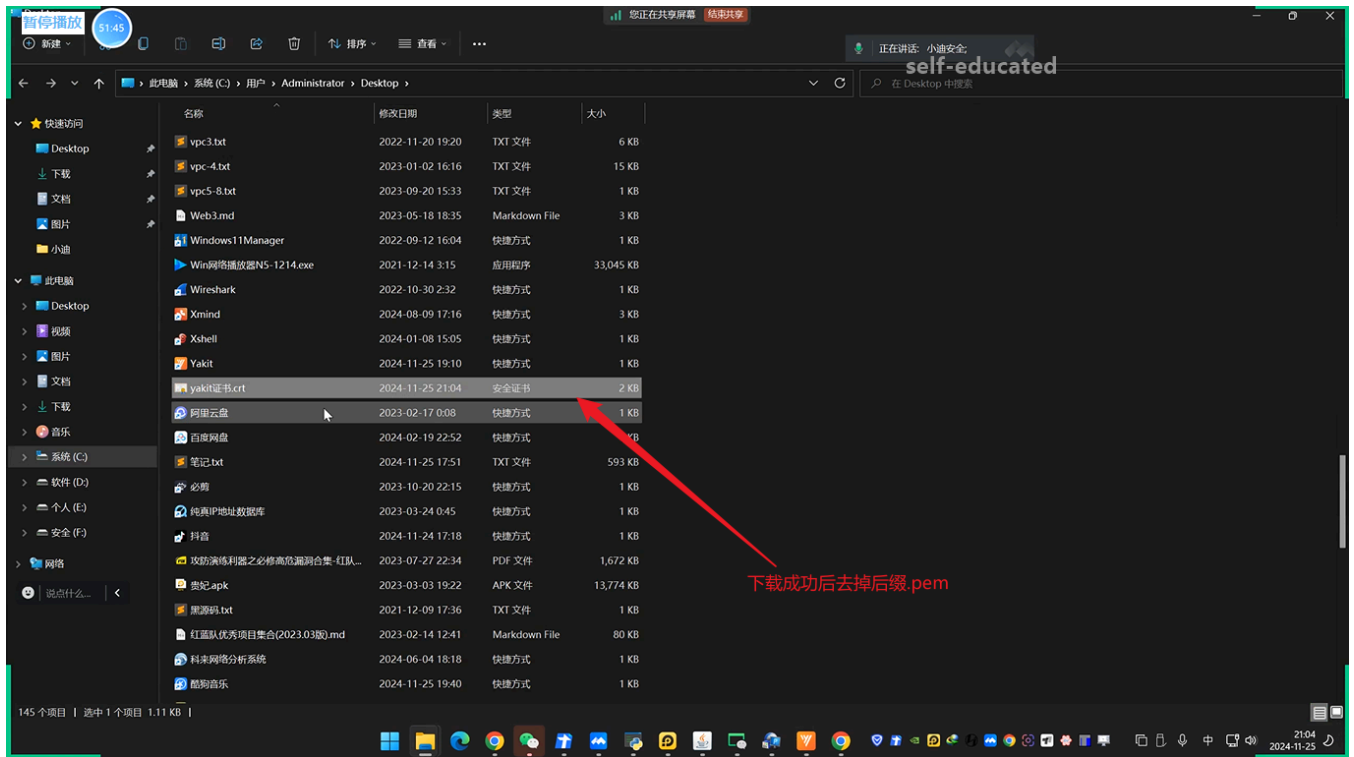


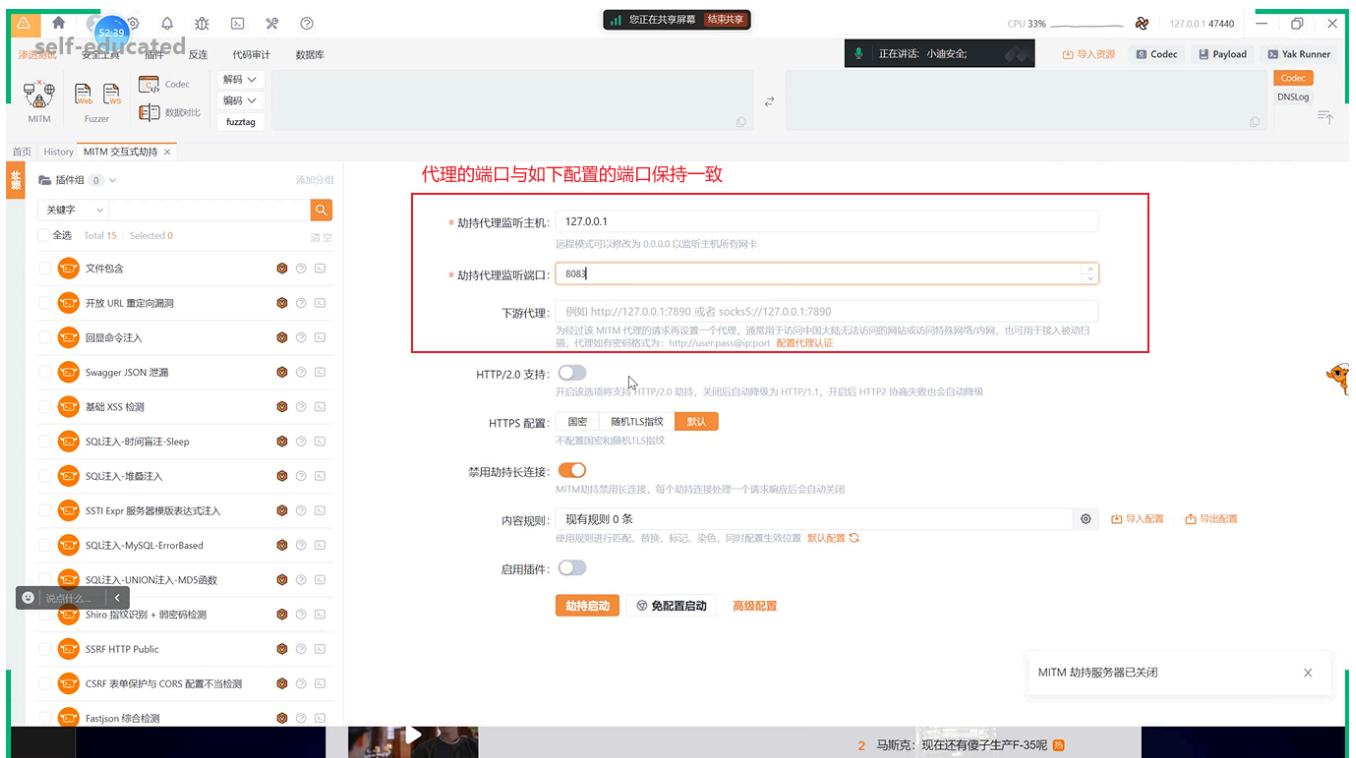
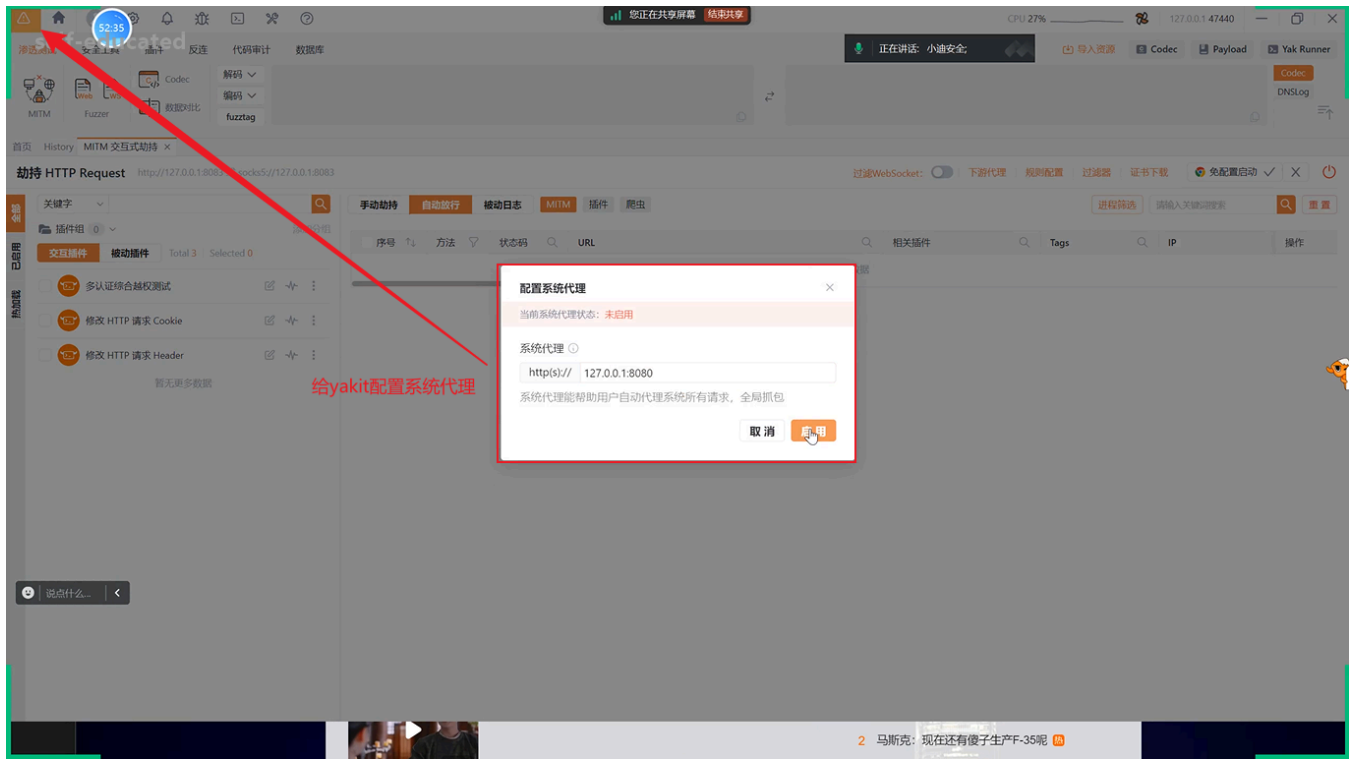
3.1.5 Web-Yakit











self-educated

52:53

您正在共享屏幕 结束共享

CPU 71% 127.0.0.1 47440

正在讲话: 小迪安全;

导入资源 Codec Payload Yak Runner

MITM Fuzzer 数据对比 fuzztag

首页 History MITM 交互式劫持

劫持 HTTP Request http://127.0.0.1:8083 或 socks5://127.0.0.1:8083

过滤WebSocket: 下游代理 规则配置 过滤器 证书下载 免配置启动

进程筛选 请输入关键词搜索

关键字 插件组 添加分组

交互插件 被动插件 Total 3 Selected 0

多认证综合授权测试

修改 HTTP 请求 Cookie

序号 方法 状态码 URL 相关插件 Tags IP 操作

178	POST	200	https://otheve.beacon.qq.com/analytics/v2_upload?appkey=0WE805...	-	-	113.240.72.99	操作
177	GET	200	https://mbd.baidu.com/ztbox?action=zblog&v=2.0&appname=bai...	-	-	180.101.49.57	操作
176	GET	200	https://mbd.baidu.com/ztbox?action=zblog&v=2.0&appname=bai...	-	-	180.101.49.57	操作
175	GET	200	https://mbd.baidu.com/ztbox?action=zblog&v=2.0&appname=bai...	-	-	180.101.49.57	操作

百度

启动成功后, 访问网页, yakit能抓到对应的流量

百度一下

我的关注 推荐

推荐

百度热搜

站在历史正确的一边

警方通报: 王宝强被举报涉嫌诈骗

马斯克: 现在还有傻子生产F-35呢

self-educated

53:53

您正在共享屏幕 结束共享

CPU 25% 127.0.0.1 47440

正在讲话: 小迪安全;

导入资源 Codec Payload Yak Runner

MITM Fuzzer 数据对比 fuzztag

首页 History MITM 交互式劫持

插件组 添加分组

关键字 插件组 添加分组

全选 Total 15 Selected 15 清空

- ☒ 文件包含
- ☒ 开放 URL 重定向漏洞
- ☒ 回显命令注入
- ☒ Swagger JSON 漏洞
- ☒ 基础 XSS 检测
- ☒ SQL注入-时间盲注-Sleep
- ☒ SQL注入-堆叠注入
- ☒ SSTI Expr 服务器模板表达式注入
- ☒ SQL注入-MySQL-ErrorBased
- ☒ SQL注入-UNION注入-MD5函数
- ☒ Shiro 指纹识别 + 弱密码检测
- ☒ SSRF HTTP Public
- ☒ CSRF 表单保护与 CORS 配置不当检测
- ☒ Fastjson 综合检测

劫持代理监听主机: 127.0.0.1

远程模式可以修改为 0.0.0.0 以监听主机所有网卡

劫持代理监听端口: 8083

下游代理: 例如 http://127.0.0.1:7890 或 socks5://127.0.0.1:7890

为经过 MITM 代理的请求再设置一个代理, 通常用于访问中国大陆无法访问的网站或访问特殊网络/内网, 也可用于接入被劫持。代理如有密码格式为: http://user:pass@ip:port 配置代理认证

HTTP/2.0 支持: ☐

开启该选项将支持 HTTP/2.0 劫持, 关闭后自动降级为 HTTP/1.1, 开启后 HTTP/2 协商失败也会自动降级

HTTPS 配置: 固定 随机TLS指纹 默认

随机TLS指纹: 随机生成合法的 TLS (GM-TLS) 劫持, 对目标网站发起固定 TLS 的连接

禁用劫持长连接: ☐

MITM劫持禁用长连接, 每个劫持连接处理一个请求响应后会自动关闭

内容规则: 现有规则 0 条

使用规则进行匹配、替换、标记、染色, 同时配置生效位置 默认配置 导入配置 导出配置

启用插件: ☐

劫持启动 免配置启动 高级配置

在劫持的时候可以勾选启用插件

正在共享屏幕 结束共享

CPU 49% 127.0.0.1 47440

正在讲话: 小迪安全

导入资源 Codex Payload Yak Runner

MITM Fuzzer 数据对比 fuzztag

首页 History MITM 交互式劫持

劫持 HTTP Request http://127.0.0.1:8083 或 socks5://127.0.0.1:8083

过滤WebSocket: 下游代理 规则配置 过滤器 证书下载 免配置启动

手动劫持 自动运行 被动日志 MITM 插件 爬虫

进程筛选 请输入关键词搜索

检测到加载15个插件, 如抓包有问题可点击清空取消加载插件

交互插件 被动插件 全选 Total 15 Selected 15

文件包含 开放 URL 重定向漏洞 回显命令注入 Swagger JSON 漏洞 基础 XSS 检测 SQL注入-时间盲注-Sleep SQL注入-堆叠注入 SSTI Expr 服务器模板表达式注入 SQL注入-MySQL-ErrorBased SQL注入-MySQL-Union注入-MD5函数 Shiro 指纹识别 + 弱密码检测 SSRF HTTP Public CSRF 表单保护与 CORS 配置不当检测 Fastjson 综合检测

序号 响应长度 Title 参数 响应类型 请求时间 请求大小 操作

1504	44.3K	-		ttf	21:06:46	4158	
1479	59.7K	-		javascript	21:06:46	3678	
1454	7.1K	-		javascript	21:06:45	3408	
1446	5K	-		x-javascript	21:06:45	3088	
822	83.6K	-		javascript	21:06:42	3108	
809	39.3K	-		javascript	21:06:42	3188	
797	10.2K	-		javascript	21:06:42	3208	

会对抓到的数据包调用对应的插件进行测试

Request id: 725

GET / HTTP/1.1
Host: xiaodis.com
Connection: keep-alive
sec-ch-ua: "Google Chrome";v="129", "Not=A?Brand";v="8", "Chromium";v="129"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Ref: ?1
Accept-Encoding: gzip, deflate, br, zstd

Response

1 HTTP/1.1 502: Bad Gateway
2 Content-Type: text/html; charset=utf-8
3 Warning: 199 "martian": dial tcp 47.75.212.155:443: connect: No connection could be made because the target machine actively refused it. "Mon, 25 Nov 2024 21:06:37 GMT"
4
5

3.1.6 小程序-Yakit

正在共享屏幕 结束共享

CPU 27% 127.0.0.1 47440

正在讲话: 小迪安全

导入资源 Codex Payload Yak Runner

MITM Fuzzer 数据对比 fuzztag

首页 History MITM 交互式劫持

关键字 插件组 添加分组

全选 Total 15 Selected 0 清空

文件包含 开放 URL 重定向漏洞 回显命令注入 Swagger JSON 漏洞 基础 XSS 检测 SQL注入-时间盲注-Sleep SQL注入-堆叠注入 SSTI Expr 服务器模板表达式注入 SQL注入-MySQL-ErrorBased SQL注入-MySQL-Union注入-MD5函数 Shiro 指纹识别 + 弱密码检测 SSRF HTTP Public CSRF 表单保护与 CORS 配置不当检测 Fastjson 综合检测

说说什么

yakit配置监听的主机和端口

* 劫持代理监听主机: 127.0.0.1
远程模式可以修改为 0.0.0.0 以监听主机所有网卡

* 劫持代理监听端口: 8083

下游代理: 例如 http://127.0.0.1:7890 或者 socks5://127.0.0.1:7890
为经过该 MITM 代理的请求再设置一个代理, 通常用于访问中大型无法访问的网站或访问特殊网络/内网, 也可用于接入被动扫描。代理如有密码格式为: http://userpass@ip:port 配置代理认证

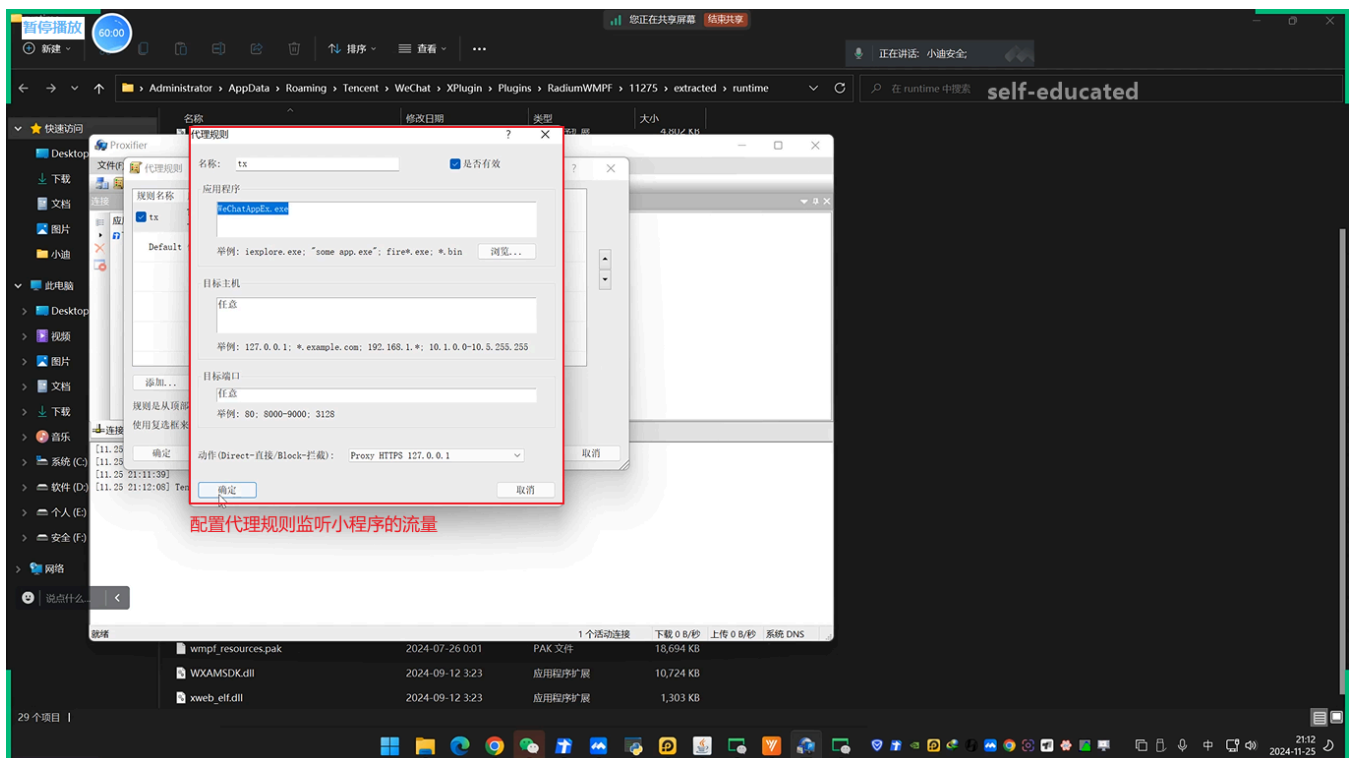
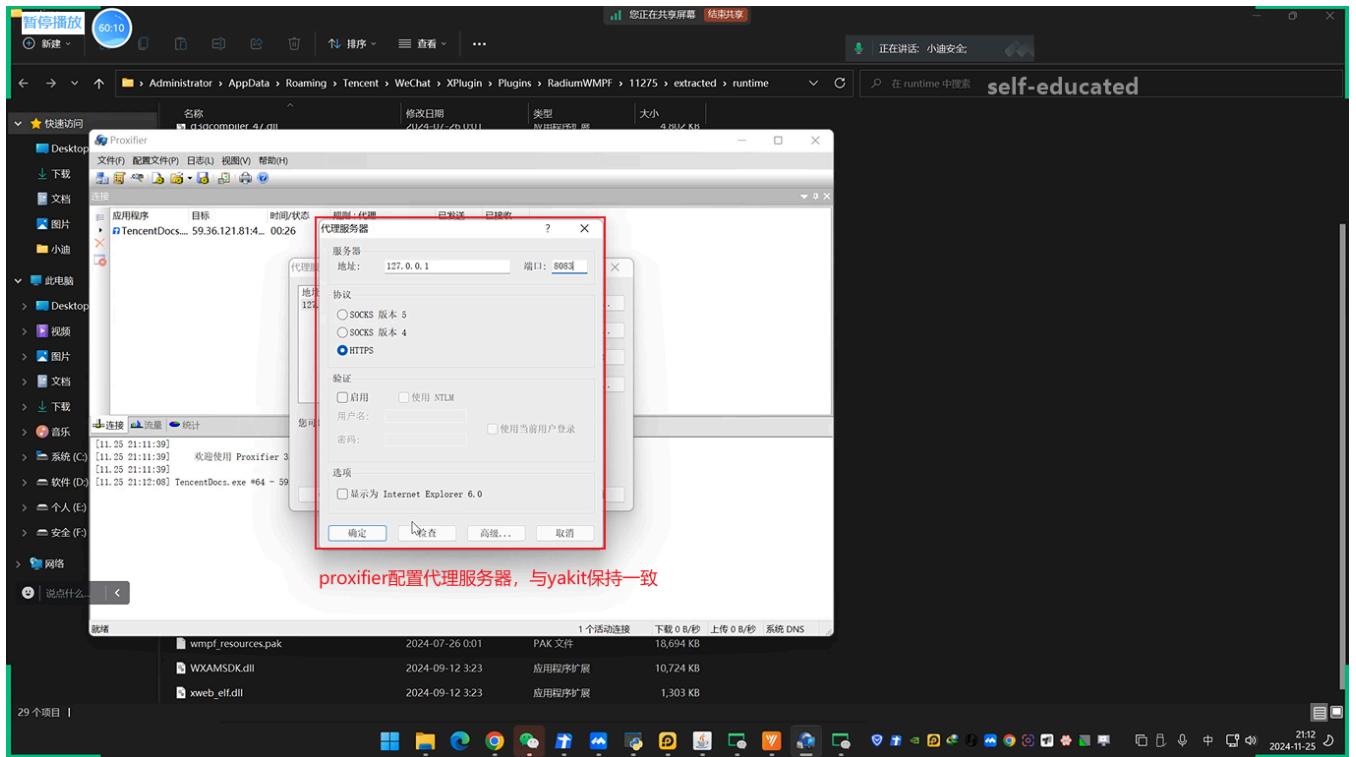
HTTP/2.0 支持: 开启该选项将支持 HTTP/2.0 劫持, 关闭后自动降级为 HTTP/1.1, 开启后 HTTP/2 协商失败也会自动降级

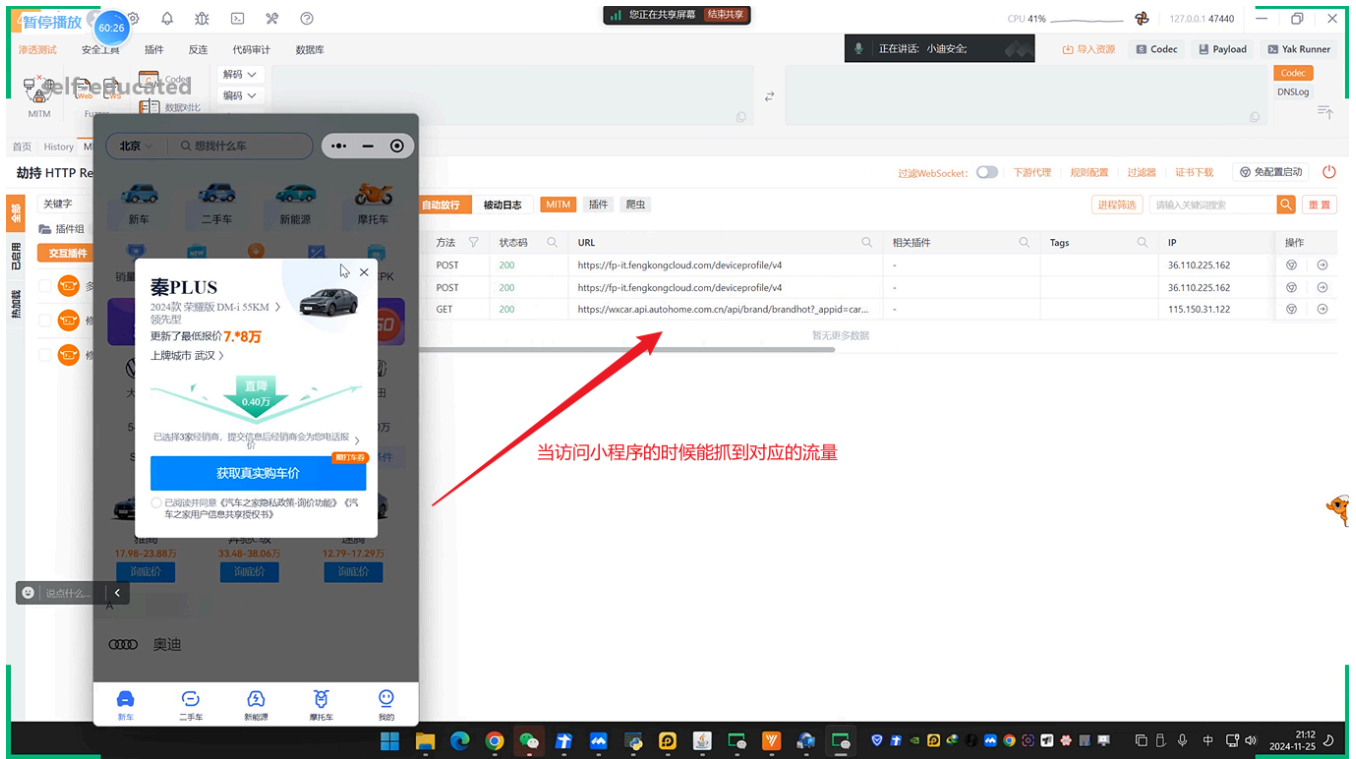
HTTPS 配置: 固定 随机TLS指纹 默认
不配置固定和随机TLS指纹

禁用劫持长连接: 开启
MITM劫持禁用长连接, 每个劫持连接处理一个请求响应后会自动关闭

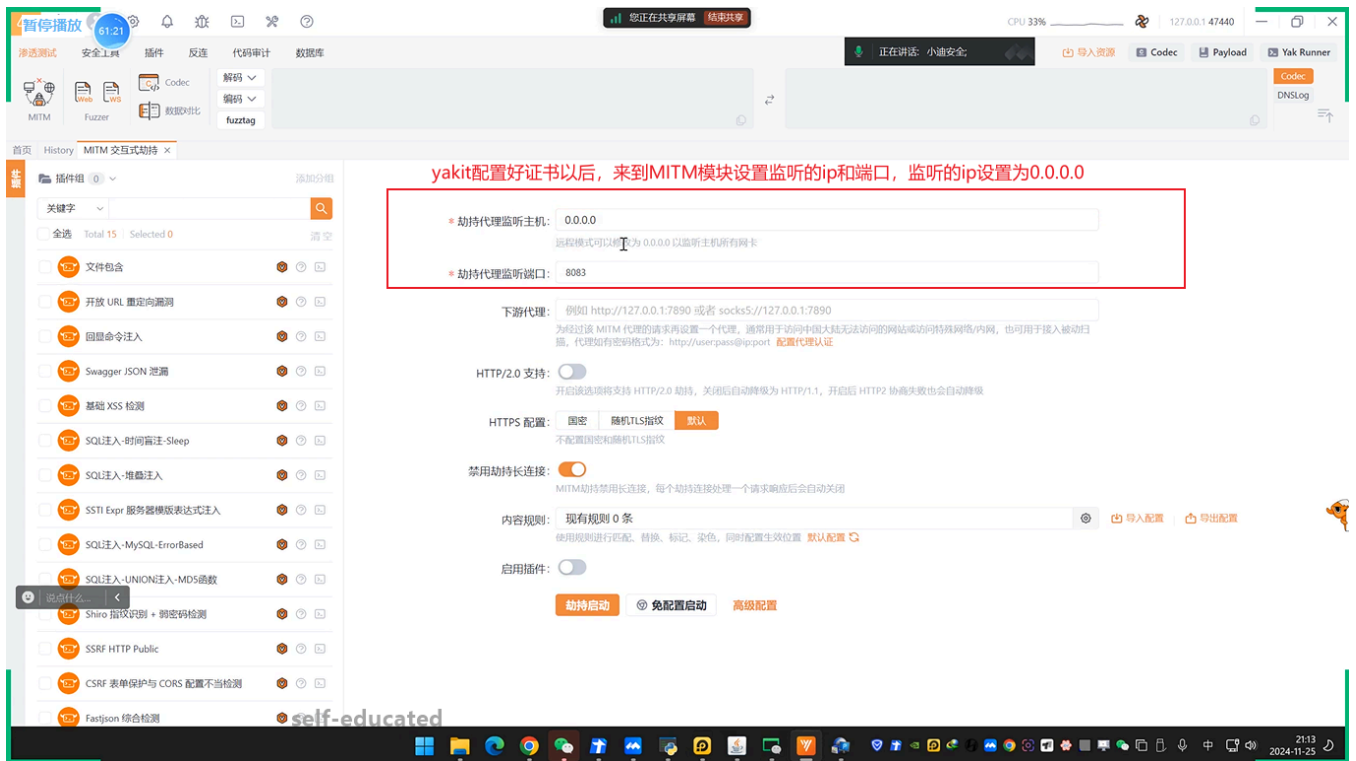
内容规则: 现有规则 0 条
使用规则进行匹配、替换、标记、染色, 同时配置生效位置 默认配置

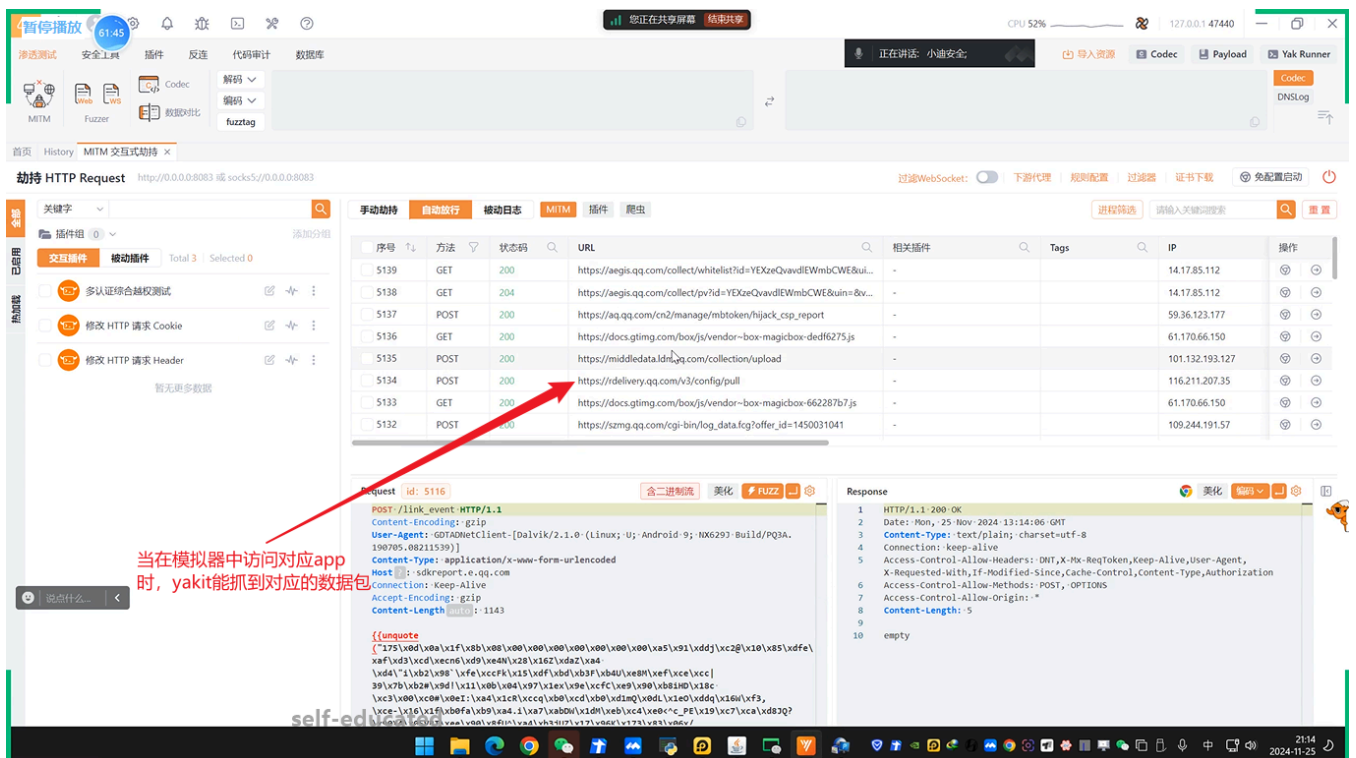
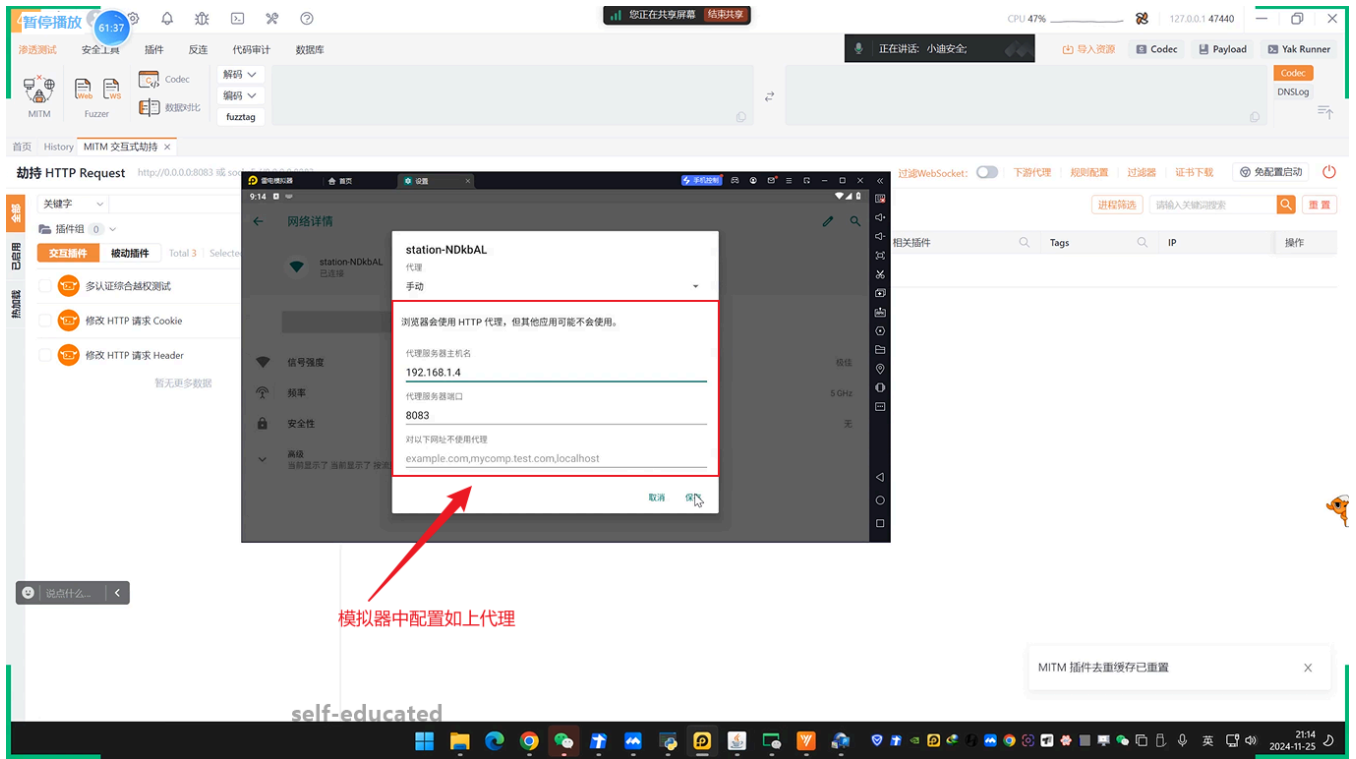
启用插件: 劫持劫持 免配置启动 高级配置





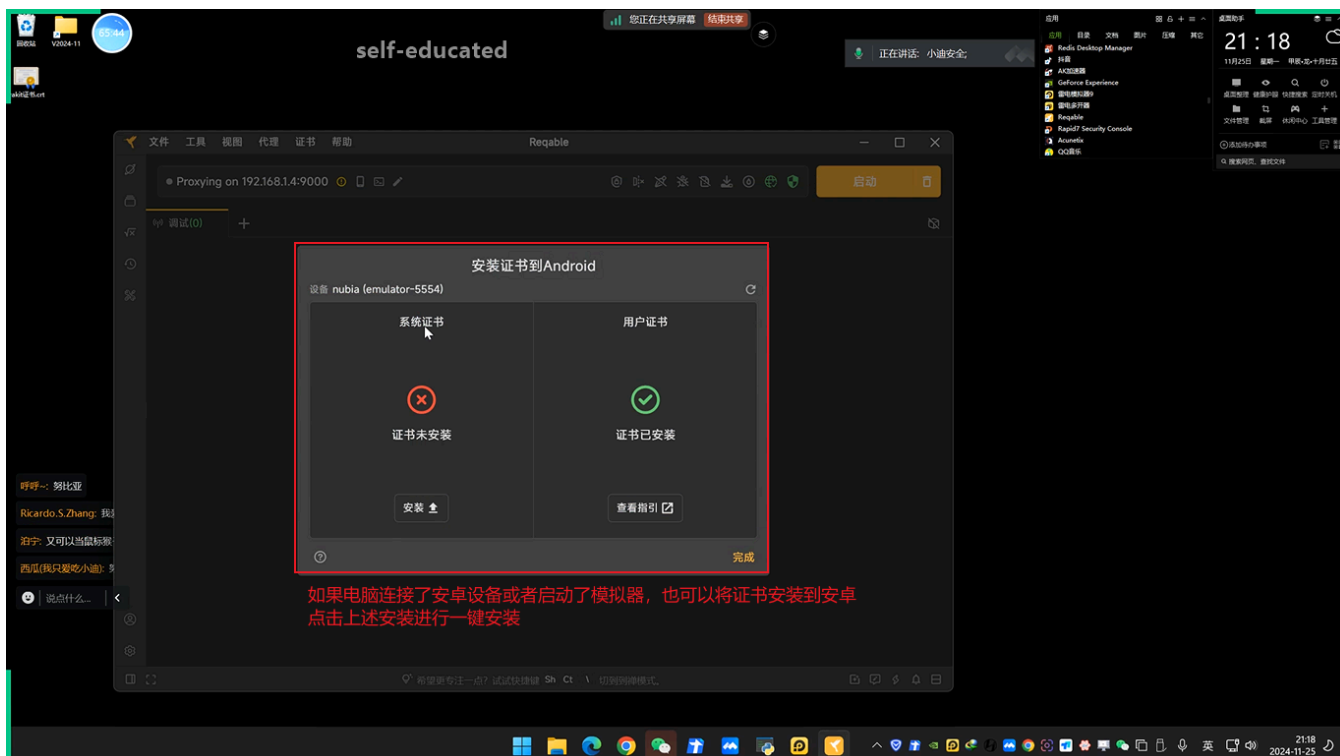
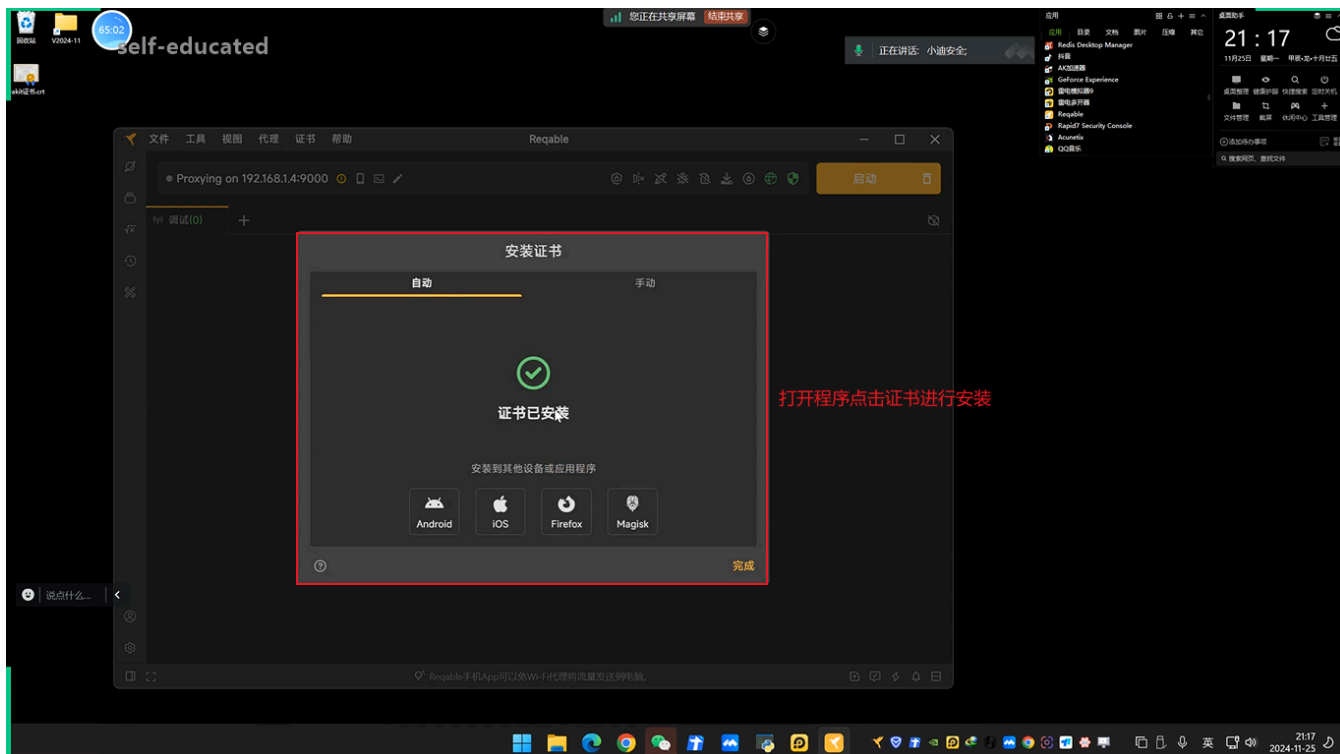
3.1.7 APP-Yakit

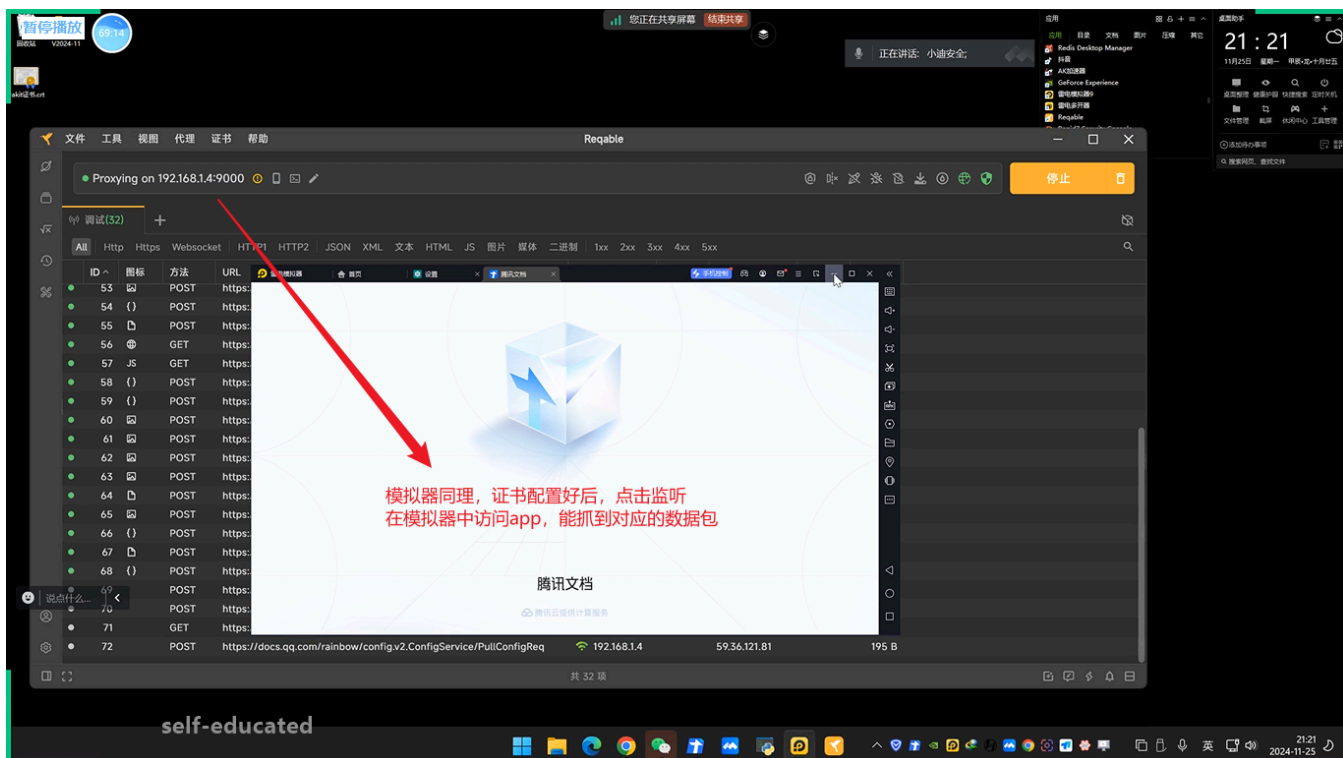
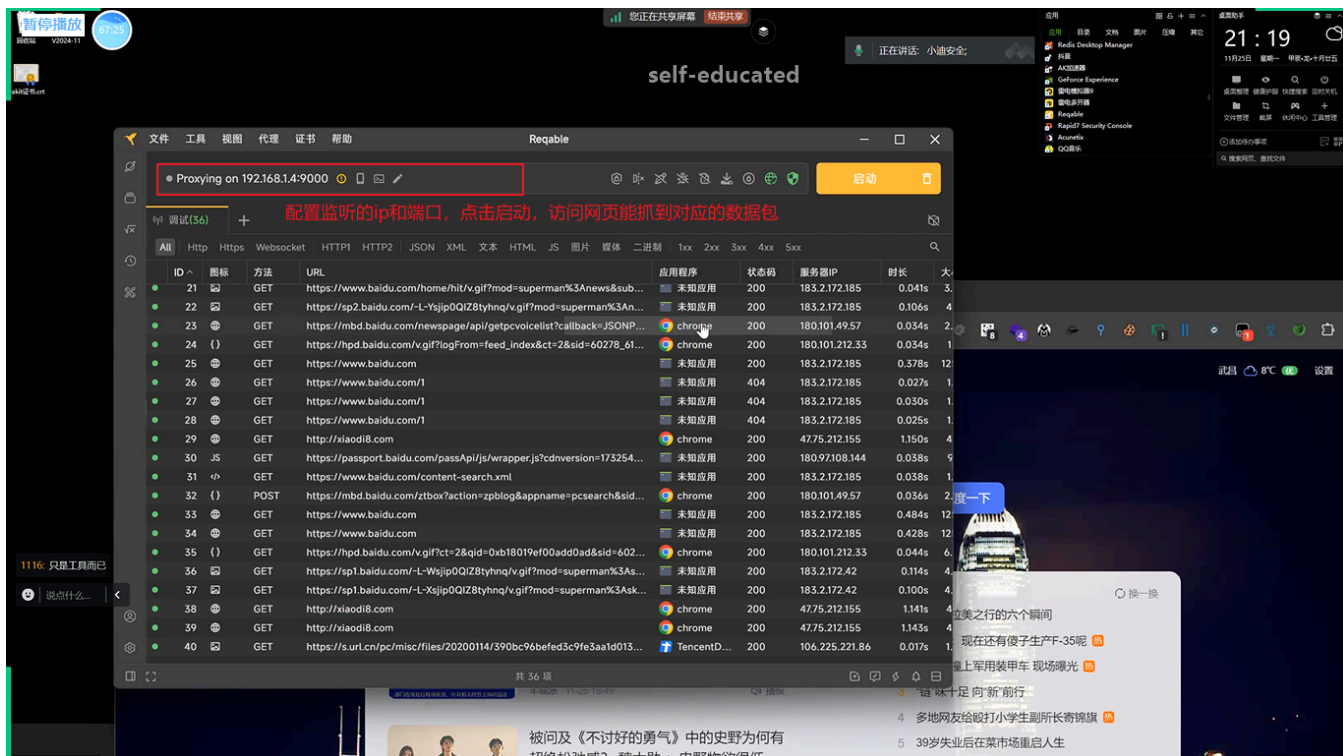


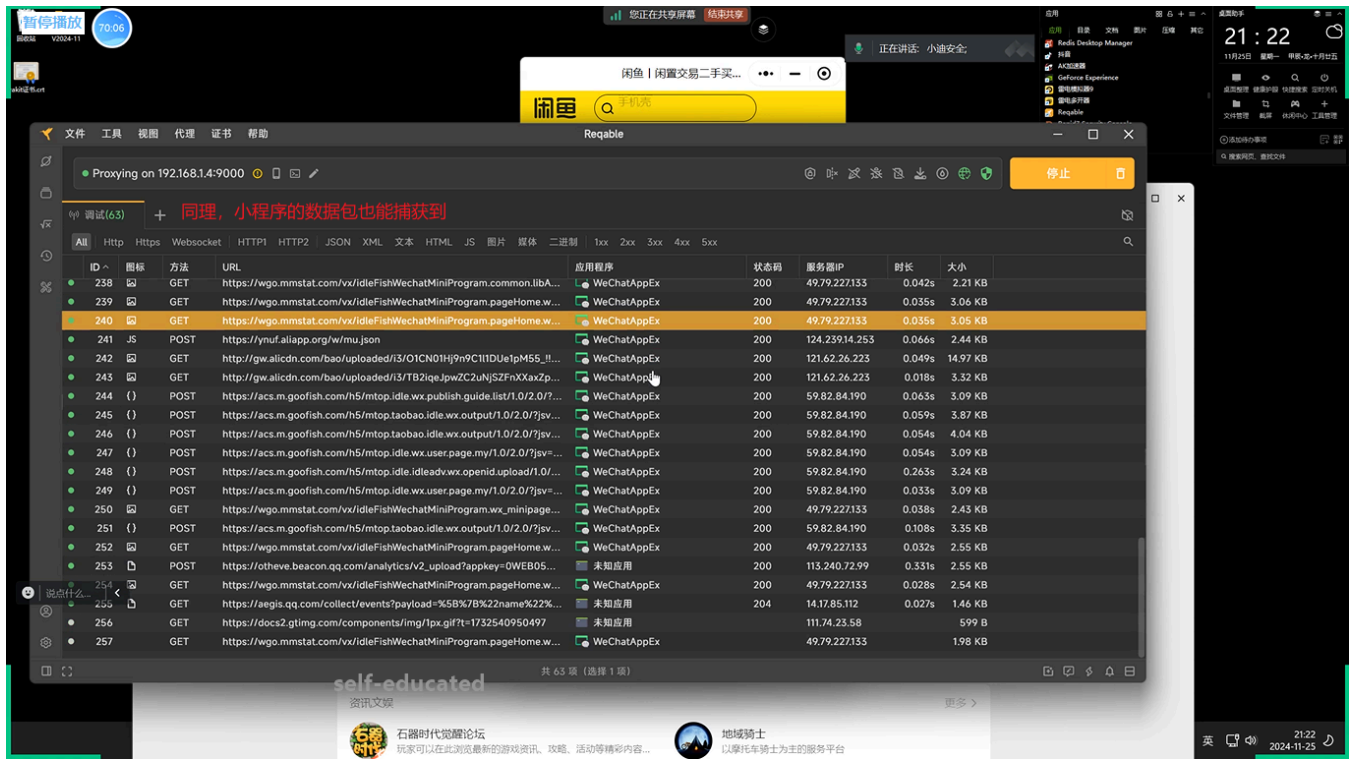


3.2 抓包技术-软件联动&通用方案-Proxifier&Reqable

3.2.1 Reqable







- 1 联动参考day07的课件。